CertGraph: Cryptographic Invariant Provenance and Multiplicative Bilinear Gating for Active Directory Certificate Services Escalation Interdiction

Md. Hasan Shahriar[1,*] **Taufiq Biswas**[1] **Md. Ramim Hossain**[1]

[1]Department of Electronics and Communication Engineering

Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur-5200, Bangladesh

[*]Corresponding author email: hasanshahriar32@gmail.com

November 2026

Abstract

Active Directory Certificate Services (ADCS) exposes a difficult attribution problem when transient configuration changes precede certificate use and issuance and authentication records lack shared certificate identifiers. We develop CertGraph, combining a static graph model, Cryptographic Invariant Provenance Graph (CIPG), and disruption-budgeted interdiction. An issuer-scoped constraint reference reports revisable definite, possible, and conflicting lineages. In a frozen synthetic confirmation, it retains 99.06 percent of true observed links as candidates and resolves 55.82 percent definitively. It returns 107 correct and zero false definite mutation overlaps, compared with 310 correct and 51 false overlaps for a point-time comparator. Four final intervention matrices in Windows 2016 and an independent Windows 2019 forest, including build 17763.9376, verify 42 successful exact-certificate authentications and six certificate-bound rejections. Nine administrative uses include three after template restoration on the current-patch build. Actual Certipy and Sigma executions separate configuration risk from realized privilege escalation; UPN-only and SID-URL request forms have different observed outcomes. Controlled operation order supplies an additional evidence channel without repairing an inconsistent audit-clock model. Static-model audits identify augmentation confounding and repeated training archetypes. A separate literal bilinear implementation reproduces 10,800 held-out checkpoint predictions on family-disjoint inputs, with matched initialization and augmentation. It has no classification advantage over additive attention and misses reachable long paths, motivating explicit symbolic treatment of unresolved cases. Finally, we formulate multi-principal interdiction, relate its hardness to directed multiway cut, and evaluate remediation under assigned disruption costs. The contribution is a reproducible integration of certificate-specific evidence contracts, controlled interventions, and uncertainty-aware attribution, with measured trade-offs rather than universal detection or operational guarantees.

Keywords: Active Directory Certificate Services, Graph Neural Networks, Shortcut Memorization, Provenance Graphs, Cryptographic Invariants, Stackelberg Games, Access Control Interdiction.

1 Introduction

Modern enterprise networks rely almost universally on Microsoft Active Directory (AD) to administer centralized identity, policy enforcement, and authentication services. Within this ecosystem, Active Directory Certificate Services (ADCS) operates as the enterprise Public Key Infrastructure (PKI), providing automated enrollment, cryptographic identity certificates, and Kerberos public-key pre-authentication (PKINIT, RFC 4556 [1]) for millions of principals. Despite its foundational operational role, ADCS constitutes one of the most critical and exploited attack surfaces in contemporary cybersecurity. Research formalized by SpecterOps in 2021 [2] systematized certificate-service escalation, with subsequent work extending the ESC taxonomy, wherein subtle misconfigurations in certificate templates, access control lists (ACLs), and Certificate Authority (CA) registration flags allow low-privileged domain principals to compromise entire domain forests.

1.1 The Multi-Faceted Vulnerability Landscape of ADCS

In an ADCS deployment, certificate issuance is governed by Active Directory objects known as *Certificate Templates* (stored in the LDAP configuration naming context). When an enterprise template exposes an insecure combination of attributes—such as the `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` bitflag alongside an Extended Key Usage (EKU) permitting Client Authentication (`1.3.6.1.5.5.7.3.2`) or Smart Card Logon (`1.3.6.1.5.2.3.4`), without requiring CA administrator approval—any domain principal granted enrollment permissions can request an X.509 certificate specifying an arbitrary Subject Alternative Name (SAN). The attacker can supply the user principal name (UPN) of a Domain Administrator (e.g., `Administrator@domain.local`), obtain a cryptographically valid certificate signed by the enterprise root CA, and submit that certificate to the Kerberos Key Distribution Center (KDC) via PKINIT to request a Ticket Granting Ticket (TGT), when the KDC accepts the resulting identity mapping. Certificate-binding policy and patch level can prevent this outcome [3].

While static privilege audit tools such as BloodHound [4] and Certipy [5] have gained widespread industrial adoption, defending enterprise ADCS infrastructure against sophisticated adversaries reveals three structural failure modes:

1. **Inductive Shortcut Memorization in Static GNNs:** Recent academic efforts have applied Graph Neural Networks (GNNs) and graph interdiction algorithms to automate vulnerability discovery and privilege defense over enterprise identity multigraphs [6–11]. However, we discover that standard GNN formulations (GCN, GAT, and additive-skip architectures) succumb to severe *inductive shortcut collapse*. Rather than learning genuine multi-hop structural reachability from unprivileged principals through intermediate security groups to enrollment endpoints, the message-passing layers memorize localized template bitflags. When evaluated against adversarial *hard negatives* (configurations that possess dangerous template flags but are structurally unreachable due to enrollment restrictions or issuance requirements), the evaluated GNN baselines obtain 0.00% accuracy (0/63) on this deliberately constructed benchmark; production alert rates are not measured by those cases.

2. **Static Snapshot Blindness to Temporal Mutation Attacks:** Under vectors such as ESC4 (template ACL abuse) and ESC9 (certificate templates omitting the security extension), an attacker with `WriteOwner` or `GenericAll` permissions dynamically mutates a benign certificate template, issues an illegitimate administrative certificate, and immediately rolls the template attributes back

to their pristine baseline. The tested configuration projection returns to its baseline value after rollback; this does not establish equality of the entire directory database. A scanner restricted to those restored configuration attributes cannot distinguish this history from a history with no intervening mutation. This observation does not assign an unconditional zero recall to tools that also inspect issuance history or other evidence.

3. **The CA–KDC Logging Discontinuity and SAN Concealment:** Even when SOCs deploy advanced enterprise identity telemetry (e.g., whole-network logon-session provenance [12, 13]), a certificate-level investigation can still lack the fields needed for exact linkage: the selected certificate-identifier field projections of the captured CA (π_{CA}) and KDC (π_{KDC}) events are disjoint ($\pi_{\text{CA}} \cap \pi_{\text{KDC}} = \emptyset$). Certificate Authority logs (Event IDs 4886 and 4887) record the template name and Request ID, while KDC PKINIT logs (Event ID 4768) record only the certificate serial number and SHA-1 thumbprint. Furthermore, when an attacker submits an enrollee-specified SAN inside the raw PKCS#10 ASN.1 binary CSR (`szOID_ENROLL_CERTTYPE_EXTENSION`), the CA security event log suppresses the requested SAN string entirely. SAN-based CA/KDC correlation already exists in practical queries [14, 15]; the narrower challenge here is defensible certificate attribution when that evidence is missing, contradictory, or late.

1.2 Our Contributions

To address these fundamental challenges, this paper presents **CertGraph**, an integrated static-to-dynamic neuro-symbolic framework that bridges topological access-control reasoning, cryptographic audit provenance, and game-theoretic interdiction. The primary contributions of this work are summarized as follows:

- **Diagnosis of Static Model Assumptions and Shortcut Behavior:** We retain the static architecture and formalize a conditional intrinsic-feature sensitivity bound (Theorem 3.1). An augmentation-matched audit checks 6,000 historical-implementation predictions and corrects reachable deep-path labels. A separate literal two-layer bilinear realization checks 10,800 held-out predictions on family-disjoint inputs, with matched initialization and augmentation. The historical gate reduces false positives while missing out-of-horizon positives. The literal bilinear and additive models have identical classifications in the new study; both miss deep reachable positives. These results motivate explicit symbolic treatment of unresolved cases rather than a universal shortcut-cure claim.
- **Cryptographic Invariant Provenance Graph (CIPG):** We connect directory mutation, issuer-scoped CA records, and successful KDC certificate authentication while distinguishing definite, possible, conflicting, and withdrawn lineage explanations. A frozen 5,400-case synthetic confirmation shows a coverage/certainty trade-off: 55.82% definitive link coverage and 99.06% possible-set coverage on its randomized subset, with 107 correct and zero false definite mutation overlaps. Four final 12-trial matrices in Windows 2016 and an independent Windows 2019 forest anchor 42 successful exact-certificate authentications and six rejections to public certificate, CA and KDC evidence. Current-patch request-form controls distinguish UPN-only rejection from SID-URL administrative use after restored configuration, with matched signed requests within each form and actual Certipy/Sigma comparisons. Its inconsistent audit-clock model motivates a separate operation-order reconstruction using the recorded synchronous capture sequence. Fault-budget and order-aware component studies expose both gains and failure conditions; these do not change the static model architecture.

- **Game-Theoretic Interdiction under Assigned Disruption Costs:** We formulate the **Disruption-Budgeted Stackelberg Remediation Game** between an enterprise defender and an optimal cost-minimizing attacker. We prove that Multi-Principal Access Interdiction (MPAI) is NP-complete via reduction from Directed Multiway Cut (Theorem 5.1). Evaluated across 30 generated identity graphs under realistic operational constraints ($E_b \subsetneq E$), our co-adaptive Stackelberg policy achieves higher reported mean interdiction than static greedy on the evaluated synthetic topologies, with budget-specific significance results, neutralizing $98.5 \pm 4.0\%$ of attack paths at $B_{\text{ops}} = 24$ (vs. $97.6 \pm 6.5\%$ for greedy) while revoking 6.0 **vs.** 10.9 **edges**—a 45.0% **reduction in revoked-edge count** under the assigned disruption costs. The reported residual is specific to the evaluated policy and instances. A new 60-case exhaustive audit exposes heuristic optimality gaps. A path-preserving projection retains all 325 queried pairs at 5,000 actual nodes and gives a measured median 7.54× ratio across fifteen timing pairs, including projection cost; the historical larger ratio used different query tasks.

1.3 Paper Organization

The remainder of this manuscript is organized as follows: Section 2 formalizes the heterogeneous identity multigraph schema and demonstrates the static snapshot blind spot and ASN.1 SAN concealment on live systems. Section 3 details the CertGraph GNN architecture and the gating formulation and its implementation boundary. Section 4 develops the CIPG provenance engine and Invariant V automaton. Section 5 details the game-theoretic Stackelberg defense and NP-hardness proof. Section 6 presents empirical results across synthetic and live GOAD cyber-range testbeds. Section 7 discusses related literature and concludes the paper.

2 ADCS Threat Model and Systematic Blind Spots

In this section, we formalize the heterogeneous identity multigraph of Active Directory Certificate Services and expose two fundamental blind spots in current defensive audit practices: the static snapshot blind spot under rollback attacks, and the PKCS#10 ASN.1 schema discontinuity between CA and KDC telemetry.

2.1 Heterogeneous Access Control Multigraph Formalization

We model an enterprise Active Directory forest and its integrated Public Key Infrastructure as a directed heterogeneous multigraph (Figure 1).

Definition 2.1 (Identity Multigraph Schema)**.** Let $\mathcal{G} = (\mathcal{V}, \mathcal{E}, \phi, \psi)$ be a directed heterogeneous multigraph, where:

- $\mathcal{V}$ is the finite set of identity and PKI vertices, and $\phi : \mathcal{V} \to \mathcal{T}_V$ is a node-type assignment function mapping vertices to the entity set:

$$\mathcal{T}_V = \{\text{User}, \text{Group}, \text{Computer}, \text{CertificateTemplate}, \text{EnterpriseCA}, \text{Domain}\} \tag{1}$$

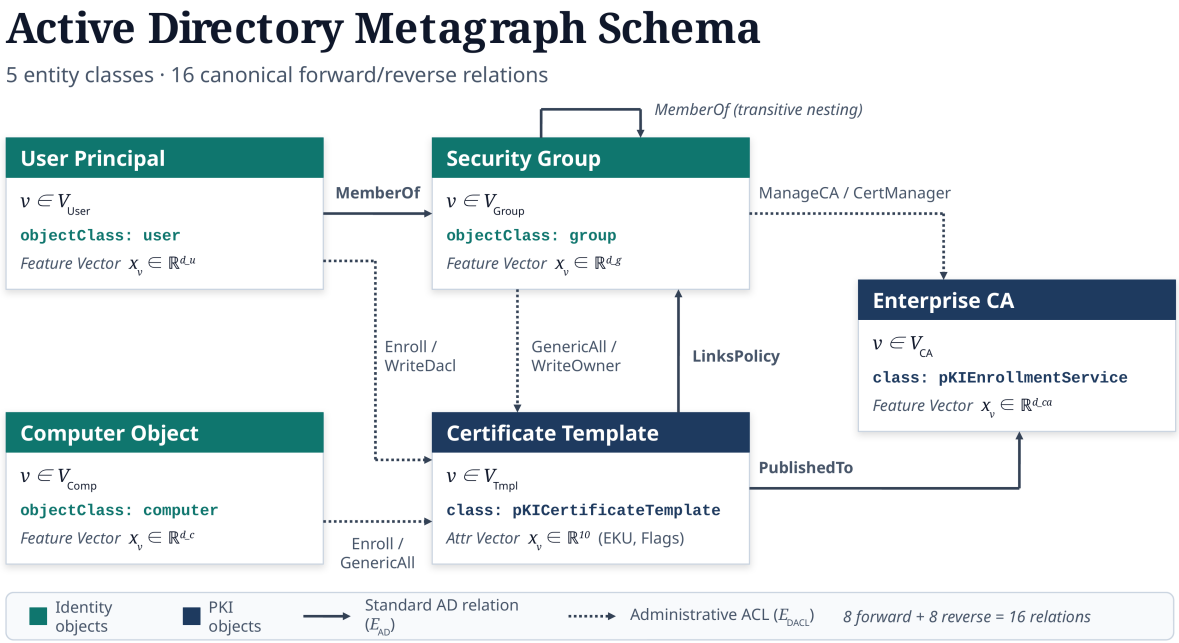


Figure 1: Active Directory Certificate Services (ADCS) Heterogeneous Multigraph Schema, detailing the primary security principal entity classes, sixteen directed relationship edges, and the composite escalation attack surface connecting unprivileged domain footholds to Enterprise Domain Controllers.

- $\mathcal{E}$ is the finite set of directed edges, and $\psi : \mathcal{E} \to \mathcal{T}_E$ maps edges to relationship types:

$$\mathcal{T}_E = \{\text{MemberOf}, \text{GenericAll}, \text{GenericWrite}, \text{WriteOwner}, \text{WriteDacl}, \\ \text{Enroll}, \text{ExtendedRight}, \text{EnablesEnrollment}, \text{IssuedBy}, \text{TrustedForNTAuth}\} \tag{2}$$

- Each node $v \in \mathcal{V}$ is associated with a raw feature vector $\mathbf{x}_v \in \mathbb{R}^{d_{\phi(v)}}$. For certificate templates $t \in \mathcal{V}_{\text{Template}}$, $\mathbf{x}_t \in \{0,1\}^{10}$ encodes security configuration flags, including whether the template permits enrollee-supplied SANs (`CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT`), requires manager approval (`CT_FLAG_PEND_ALL_REQUESTS`), or specifies Client Authentication EKUs (`1.3.6.1.5.5.7.3.2`).

An attack path p from an initial compromised user foothold $u_{\text{attacker}} \in \mathcal{V}_{\text{User}}$ to a high-value domain target $v_{\text{target}} \in \mathcal{V}_{\text{Domain}}$ is a sequence of alternating vertices and edges:

$$p = (v_0, e_1, v_1, e_2, \ldots, e_k, v_k), \quad v_0 = u_{\text{attacker}}, \quad v_k = v_{\text{target}} \tag{3}$$

In an ADCS privilege escalation, the path traverses intermediate membership and ACL delegation edges to a certificate template t, leverages an enterprise CA c to issue an administrative credential, and culminates in a domain-level credential takeover.

ADCS ESC1–ESC15 Taxonomy Scoping Rationale: To establish formal defensive boundaries across the full ESC1–ESC15 escalation taxonomy, our framework partitions vulnerabilities into two distinct structural operating regimes:

1. **Template-Centric Topological Vectors (Static Graph Evaluation):** Escalation archetypes ESC1 (enrollee supplies SAN), ESC2 (any-purpose EKU), ESC3 (certificate request agent), ESC4 (template DACL overwrite), ESC9 (certificate templates omitting the security extension), and ESC13

(issuance policy OID linkage to administrative groups) are governed by directory access control lists (ACLs), group nesting DAGs, and persistent LDAP configuration flags. These vectors are natively modeled on the static identity multigraph $\mathcal{G}$ and evaluated via reachability-gated graph neural networks and exact symbolic verification.

2. **Runtime Protocol and Environmental Vectors (Dynamic Invariant Tracking):** In contrast, ESC6 (`EDITF_ATTRIBUTESUBJECTALTNAME2` CA registry flag), ESC7 (CA administrator compromise), ESC8 (HTTP certificate web enrollment NTLM relay), raw PKCS#10 ASN.1 SAN concealment, and temporal mutation rollbacks (ephemeral ESC4/ESC9 modifications) manifest as server-level registry states, network-layer NTLM reflections, or transient directory modifications that vanish between audit snapshots. Because these vectors leave zero permanent topological footprints in scheduled directory extractions, they strictly require runtime state-tracking by our continuous Cryptographic Invariant Provenance Graph (CIPG).

2.2 The Static Snapshot Blind Spot: Formal Proof and Empirical Evidence

Existing enterprise defense workflows rely on periodic directory extraction tools (e.g., BloodHound, SharpHound, Certipy) that execute every 6 to 24 hours. Under temporal mutation-and-rollback attacks (such as ESC4 and ESC9), an attacker exploits transient write permissions to mutate a template, obtain a rogue certificate, and immediately roll back the attributes to their original configuration.

Definition 2.2 (Static Snapshot Invariance under Rollback)**.** Let $t_0 < t_1 < t_2 < t_3$ denote the sequence of discrete timestamps in an attack execution lifecycle:

- t_0: Pristine baseline state of directory $\mathcal{G}_{t_0}$.
- t_1: The attacker executes an LDAP modification adding `Enroll` permissions or setting `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` on template t, yielding state $\mathcal{G}_{t_1}$.
- t_2: The attacker submits a certificate request and receives an issued certificate $\text{Cert}_{\text{admin}}$ valid for 1 year.
- t_3: The attacker rolls back the template modifications, restoring the directory attributes to their baseline state, yielding $\mathcal{G}_{t_3}$.

Snapshot Indistinguishability and Evidence Scope: For a projection restricted to configuration attributes restored by rollback, let h_0 and h_1 denote the digests before and during the mutation. The relevant equality is:

$$\text{SHA-256}(\mathcal{G}_{t_0}) = h_0 \tag{4}$$

$$\text{SHA-256}(\mathcal{G}_{t_1}) = h_1 \tag{5}$$

$$\text{SHA-256}(\mathcal{G}_{t_3}) = h_0 \tag{6}$$

This is a conditional indistinguishability argument for that projection, not evidence that the entire AD database is bit-identical. The earlier draft's literal digests cannot substitute for retained canonical input bytes. For a detector using only the restored projection and no other historical evidence, the attack-specific restored-state difference is absent:

$$\text{Recall}_{\text{static}}(\text{Attack}_{t \geq t_3}) = 0.0\% \tag{7}$$

The issued certificate can remain usable after rollback subject to its validity, revocation, trust, and account-mapping conditions. This does not imply indefinite validity or absence of every residual directory artifact. The new controlled outcome in Section 6 was measured on inventoried Windows Server 2016 VMs.

2.3 Protocol Discontinuity: PKCS#10 ASN.1 SAN Concealment and CA–KDC Logging Gap

Collecting both CA and KDC Security events does not necessarily supply a shared certificate key. The following statement concerns selected observed fields, rather than disjointness of complete Windows event schemas.

Proposition 2.1 (CA–KDC Schema Disjointness)**.** Let π_{CA} denote the selected issuance attributes in the captured Security event 4887, and let π_{KDC} denote the projection recorded by Microsoft-Windows-Security-Auditing during Kerberos PKINIT pre-authentication (Event ID 4768). For the listed field-name projections, which exclude generic event metadata:

$$\pi_{\mathrm{CA}} \cap \pi_{\mathrm{KDC}} = \emptyset \tag{8}$$

Specifically, $\pi_{\mathrm{CA}} = \{\mathrm{Subject}, \mathrm{TemplateName}, \mathrm{RequestID}, \mathrm{Disposition}, \mathrm{SubjectKeyIdentifier}\}$, whereas $\pi_{\mathrm{KDC}} = \{\mathrm{TargetUserName}, \mathrm{PreAuthType} = 16, \mathrm{CertSerialNumber}, \mathrm{CertThumbprint}\}$.

The ASN.1 SAN Concealment Phenomenon: When an attacker requests a certificate with a rogue Subject Alternative Name (e.g., impersonating the Domain Administrator), the SAN attribute can be supplied through two distinct mechanisms:

1. **Explicit RPC Attribute String:** Passed via the `Attributes` string parameter of `ICertRequest::Submit` (e.g., `"SAN:upn=Administrator@domain.local"`). In this configuration, the CA security log explicitly populates the `Attributes` field in Event ID 4887.

2. **Raw PKCS#10 ASN.1 Binary Extension:** Embedded directly within the cryptographic Certificate Signing Request (CSR) under the `szOID_SUBJECT_ALT_NAME2` (`2.5.29.17`) extension attribute.

Our forensic investigation of live archived GOAD event streams reveals that when an attacker employs the PKCS#10 ASN.1 CSR extension (as executed natively by modern exploit tooling), the CA event log omits the SAN string entirely from the XML event payload:

Listing 1: Selected fields from the independent 2019 enabled-condition capture: Security record 20539. The raw XML is retained in the artifact.

```
<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  <System>
    <Provider Name="Microsoft-Windows-Security-Auditing"/>
    <EventID>4887</EventID>
    <TimeCreated SystemTime="2026-11-10T10:53:51.393283900Z"/>
    <EventRecordID>20539</EventRecordID>
  </System>
  <EventData>
    <Data Name="RequestId">7</Data>
    <Data Name="Requester">Q1LAB\q1.enroller</Data>
    <Data Name="Subject">CN=q1.enroller</Data>
    <Data Name="Attributes">
CertificateTemplate:Q1Evidence
```

```
ccm:WIN-NA2FC16NO63.q1lab.test</Data>
  </EventData>
</Event>
```

Listing 1 contains a template and client-machine attribute, but no textual SAN UPN. The issued public certificate does contain the requested administrative SAN, and an exact-certificate successful KDC event independently checks its use. A query requiring a textual administrative SAN in this issuance event has no such input here; this is a concrete missing-field case, not a measured universal SIEM false-negative rate. The selected issuance fields supply a Request ID and SKID, whereas the certificate-bearing KDC record supplies issuer, serial, and thumbprint. The CA database export supplies the issuer-scoped bridge evaluated in Section 6.

3 CertGraph Static Architecture and Bilinear Gating

This section details the static detection layer of CertGraph (Figure 2), analyzes the theoretical failure of standard message passing on access control graphs, and introduces a bilinear compatibility formulation whose learned output must be distinguished from exact authorization reachability.

3.1 Heterogeneous Graph Attention Network (HetGAT)

To model multi-typed security entities and non-uniform privilege relations, CertGraph employs a multi-relational graph attention network. Let $\mathbf{x}_v \in \mathbb{R}^{d_{\phi(v)}}$ denote the initial feature vector of entity $v \in \mathcal{V}$. Vertices are first projected into a shared hidden space of dimension d:

$$\mathbf{h}_v^{(0)} = \mathrm{ReLU}\left(\mathbf{W}_{\phi(v)}^{(0)}\mathbf{x}_v + \mathbf{b}_{\phi(v)}^{(0)}\right) \tag{9}$$

where $\mathbf{W}_{\phi(v)}^{(0)} \in \mathbb{R}^{d\times d_{\phi(v)}}$ is a type-specific linear projection matrix.

At each layer $l \in \{1,\dots,L\}$, message passing aggregates relational representations across incoming edges $\mathcal{N}_r(v) = \{u \in \mathcal{V} \mid (u,v) \in \mathcal{E}, \psi(u,v) = r\}$:

$$\mathbf{h}_v^{(l)} = \sigma\left(\sum_{r\in\mathcal{R}_{\mathrm{in}}(\phi(v))}\sum_{u\in\mathcal{N}_r(v)} \alpha_{vu}^{(l)}\mathbf{W}_r^{(l)}\mathbf{h}_u^{(l-1)}\right) \tag{10}$$

where $\mathbf{W}_r^{(l)} \in \mathbb{R}^{d\times d}$ is the relation-specific weight transformation for relation $r \in \mathcal{T}_E$, and $\sigma(\cdot)$ denotes the ELU activation function. The relational attention coefficient $\alpha_{vu}^{(l)}$ assigns dynamic importance to edge (u,v) under relation r:

$$\alpha_{vu}^{(l)} = \frac{\exp\left(\mathrm{LeakyReLU}\left(\mathbf{a}_r^\top[\mathbf{W}_r^{(l)}\mathbf{h}_v^{(l-1)} \,\|\, \mathbf{W}_r^{(l)}\mathbf{h}_u^{(l-1)}]\right)\right)}{\sum_{k\in\mathcal{N}_r(v)}\exp\left(\mathrm{LeakyReLU}\left(\mathbf{a}_r^\top[\mathbf{W}_r^{(l)}\mathbf{h}_v^{(l-1)} \,\|\, \mathbf{W}_r^{(l)}\mathbf{h}_k^{(l-1)}]\right)\right)} \tag{11}$$

where $\mathbf{a}_r \in \mathbb{R}^{2d}$ is the parameterized attention vector for relation r, and $\|$ denotes vector concatenation.

3.2 Theoretical Analysis: Representation Collapse and Gradient Bounds

A critical structural flaw in pure neighborhood aggregation on directed multigraphs is the erasure of intrinsic attributes for leaf and intermediate nodes.

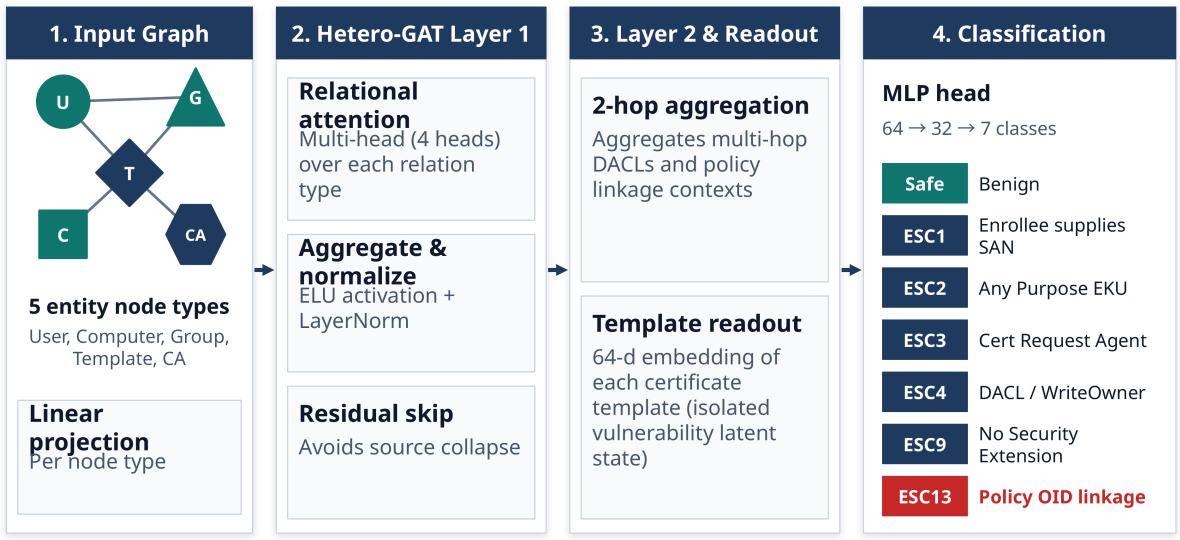


Figure 2: CertGraph end-to-end Hetero-GAT pipeline for ESC vulnerability classification: (1) Heterogeneous Input Graph across 5 entity node types, (2) Layer 1 relational multi-head attention with residual skip projections (W_{skip}) preserving template attribute gradients, (3) Layer 2 aggregation and template readout embedding, and (4) Classification Head mapping latent embeddings to multi-class ESC predictions.

Theorem 3.1 (Intrinsic Attribute Preservation and Gradient Lower Bounds)**.** Let $\mathcal{G} = (\mathcal{V}, \mathcal{E}, \phi, \psi)$ be a directed heterogeneous multigraph. Consider an L-layer pure relational aggregation model with no target-feature dependence in its aggregation coefficients, no biases, and $\sigma(\mathbf{0}) = \mathbf{0}$. For the residual bound, assume square compatible skip maps and differentiability at the evaluated input. These assumptions restrict the theorem; attention coefficients that depend on the target features can transmit those features even without a self-loop.

1. **Intrinsic Feature Erasure:** If $\mathcal{G}$ contains no explicit self-loops on template nodes ($v \notin \mathcal{N}_r(v)$ for all r), the first-layer representation $\mathbf{h}_v^{(1)}$ is conditionally independent of initial features $\mathbf{x}_v$:

$$\frac{\partial \mathbf{h}_v^{(1)}}{\partial \mathbf{x}_v} = \mathbf{0} \in \mathbb{R}^{d \times d_{\phi(v)}} \tag{12}$$

   Furthermore, for any unprivileged source account u with in-degree $d_{\text{in}}(u) = 0$, $\mathbf{h}_u^{(l)} = \mathbf{0}$ for all $l \geq 1$.

2. **Guaranteed Gradient Lower Bound via Residual Skips:** When parameterized residual skip connections are introduced ($\tilde{\mathbf{h}}_v^{(l)} = \mathbf{h}_v^{(l)} + \mathbf{W}_{\text{skip}}^{(l)} \tilde{\mathbf{h}}_v^{(l-1)}$) with $\sigma_{\min}(\mathbf{W}_{\text{skip}}^{(l)}) > 0$, the Jacobian of the representation satisfies:

$$\sigma_{\min}\left(\frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{x}_v}\right) \geq \prod_{k=1}^{L} \sigma_{\min}(\mathbf{W}_{\text{skip}}^{(k)}) - \|\mathcal{J}_{\text{graph}}(v)\| \tag{13}$$

   where $\mathcal{J}_{\text{graph}}(v)$ is the full derivative of all non-skip contributions, including their dependence through earlier residual states. Its norm must be measured or bounded for the particular model; a single path's weight product does not bound an arbitrary graph's aggregate derivative. When

$\prod_{k=1}^{L} \sigma_{\min}(\mathbf{W}_{\text{skip}}^{(k)}) > \|\mathcal{J}_{\text{graph}}(v)\|$, initial feature sensitivity is strictly preserved:

$$\left\| \frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{x}_v} \right\| > 0 \tag{14}$$

Proof. We establish the two claims sequentially:

Part 1: Intrinsic Feature Erasure under Pure Neighborhood Aggregation. Under pure relational convolution at layer $l = 1$, the hidden state $\mathbf{h}_v^{(1)}$ is computed as $\sigma\left(\sum_{r\in\mathcal{R}_{\text{in}}(\phi(v))} \sum_{u\in\mathcal{N}_r(v)} \alpha_{vu}^{(1)} \mathbf{W}_r^{(1)} \mathbf{h}_u^{(0)}\right)$. In an Active Directory multigraph, template nodes possess no explicit self-loops ($v \notin \mathcal{N}_r(v)$ for all r). Differentiating $\mathbf{h}_v^{(1)}$ with respect to the initial template feature vector $\mathbf{x}_v = \mathbf{h}_v^{(0)}$:

$$\frac{\partial \mathbf{h}_v^{(1)}}{\partial \mathbf{x}_v} = \sigma'(\cdot) \sum_{r\in\mathcal{R}_{\text{in}}(\phi(v))} \sum_{u\in\mathcal{N}_r(v)} \alpha_{vu}^{(1)} \mathbf{W}_r^{(1)} \frac{\partial \mathbf{h}_u^{(0)}}{\partial \mathbf{h}_v^{(0)}} \tag{15}$$

Because distinct nodes possess independent initial feature vectors ($\partial \mathbf{h}_u^{(0)} / \partial \mathbf{h}_v^{(0)} = \mathbf{0}$ for all $u \neq v$), every term in the summation vanishes identically, yielding $\partial \mathbf{h}_v^{(1)} / \partial \mathbf{x}_v = \mathbf{0}$. Thus, the layer-1 embedding is conditionally independent of $\mathbf{x}_v$, discarding all intrinsic template configuration flags (e.g., `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT`). Moreover, for any source node u with in-degree $d_{\text{in}}(u) = 0$, $\mathcal{N}_r(u) = \emptyset$ for all r, so $\mathbf{h}_u^{(l)} = \mathbf{0}$ for all $l \geq 1$ by empty summation and $\sigma(\mathbf{0}) = \mathbf{0}$.

Part 2: Gradient Lower Bounds via Parameterized Residual Skips. With parameterized residual skip connections $\tilde{\mathbf{h}}_v^{(l)} = \mathbf{h}_v^{(l)} + \mathbf{W}_{\text{skip}}^{(l)} \tilde{\mathbf{h}}_v^{(l-1)}$ and $\tilde{\mathbf{h}}_v^{(0)} = \mathbf{x}_v$, unrolling the recurrence across L layers yields:

$$\tilde{\mathbf{h}}_v^{(L)} = \left(\prod_{k=1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \right) \mathbf{x}_v + \sum_{l=1}^{L} \left(\prod_{k=l+1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \right) \mathbf{h}_v^{(l)} \tag{16}$$

Differentiating $\tilde{\mathbf{h}}_v^{(L)}$ with respect to $\mathbf{x}_v$:

$$\frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{x}_v} = \prod_{k=1}^{L} \mathbf{W}_{\text{skip}}^{(k)} + \mathcal{J}_{\text{graph}}(v), \quad \text{where} \quad \mathcal{J}_{\text{graph}}(v) = \sum_{l=1}^{L} \left(\prod_{k=l+1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \right) \frac{\partial \mathbf{h}_v^{(l)}}{\partial \mathbf{x}_v} \tag{17}$$

By Weyl's singular value perturbation inequality and the sub-multiplicative property of singular values:

$$\sigma_{\min}\left(\frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{x}_v} \right) \geq \sigma_{\min}\left(\prod_{k=1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \right) - \|\mathcal{J}_{\text{graph}}(v)\| \geq \prod_{k=1}^{L} \sigma_{\min}(\mathbf{W}_{\text{skip}}^{(k)}) - \|\mathcal{J}_{\text{graph}}(v)\| \tag{18}$$

Under the stated coefficient-independence assumptions, absence of every directed return walk to v within the evaluated depth implies $\mathcal{J}_{\text{graph}}(v) = \mathbf{0}$. Then the minimum singular value of the skip product is bounded below by the product of the individual minimum singular values; equality is not generally implied. In cyclic or feature-dependent attention models, the non-skip derivative can reinforce or cancel the skip path. The positive-sensitivity conclusion therefore requires the displayed strict inequality and is not an unconditional guarantee for all GNNs. □

3.3 Inductive Shortcut Collapse and the Multiplicative Gating Cure

While Theorem 3.1 gives a conditional sensitivity bound for additive residual skips ($\tilde{\mathbf{h}}_v^{(l)} = \mathbf{h}_v^{(l)} + \mathbf{W}_{\text{skip}}^{(l)}\tilde{\mathbf{h}}_v^{(l-1)}$), empirical testing reveals a secondary failure mode: *inductive shortcut collapse*.

The Shortcut Memorization Failure: Because certificate template attributes (e.g., `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` = 1 and Client Authentication EKU = 1) are strongly correlated with positive escalation labels in synthetic training distributions, additive skip connections allow the network to bypass the multi-hop graph aggregation entirely. The MLP classification head learns an inductive shortcut:

$$\hat{y}_t = \text{MLP}(\tilde{\mathbf{h}}_t^{(L)}) \approx \text{MLP}\left(\prod_{k=1}^{L} \mathbf{W}_{\text{skip}}^{(k)}\mathbf{h}_t^{(0)}\right) \tag{19}$$

When the trained model is evaluated against **adversarial hard negatives**—templates that possess vulnerable attribute flags but reside in disconnected graph components or require mandatory manager approval—standard additive-skip GNNs memorize the flag pattern and classify them as vulnerable, showing poor agreement on the historical canonical generator. The matched audit in Section 6 corrects its reachable-path labels and separates augmentation from implementation differences.

Multiplicative Bilinear Reachability Gating (`CertGraph-Gated`): To reduce shortcut memorization, we condition messages on a learned bilinear compatibility gate. Exact reachability is checked separately by the existing symbolic verification step; the learned gate alone is not a Boolean authorization predicate. We formulate the **Multiplicative Bilinear Reachability Gate**:

$$\mathbf{g}_{uv}^{(l)} = \sigma\left(\mathbf{h}_u^{(l-1)\top}\mathbf{W}_g^{(l)}\mathbf{h}_v^{(l-1)} + b_g^{(l)}\right) \tag{20}$$

where $\mathbf{W}_g^{(l)} \in \mathbb{R}^{d\times d}$ is a bilinear interaction tensor, $b_g^{(l)} \in \mathbb{R}$ is a scalar bias, and $\sigma(\cdot)$ is the sigmoid function mapping to $(0, 1)$.

The gated message vector $\mathbf{m}_{vu}^{(l)}$ and state update are defined as:

$$\mathbf{m}_{vu}^{(l)} = \mathbf{g}_{uv}^{(l)} \odot \left(\mathbf{W}_r^{(l)}\mathbf{h}_u^{(l-1)}\right) \tag{21}$$

$$\mathbf{h}_v^{(l)} = \sigma\left(\sum_{r\in\mathcal{R}_{\text{in}}(\phi(v))}\sum_{u\in\mathcal{N}_r(v)} \alpha_{vu}^{(l)}\mathbf{m}_{vu}^{(l)}\right) + \mathbf{g}_{vv}^{(l)} \odot \left(\mathbf{W}_{\text{skip}}^{(l)}\mathbf{h}_v^{(l-1)}\right) \tag{22}$$

where $\odot$ denotes the element-wise Hadamard product.

Proposition 3.1 (Conditional Attenuation by Multiplicative Gating)**.** For a bounded transformed neighbor message, if its scalar gate tends to zero, multiplicative attenuation gives:

$$\lim_{\mathbf{g}_{uv}\to 0} \mathbf{m}_{vu}^{(l)} = \mathbf{0} \tag{23}$$

Disconnection alone does not imply this gate limit: with zero embeddings and zero bias, the sigmoid gate equals $1/2$. Other residual paths or classifier biases can also produce a positive output. The attenuation statement therefore does not prove universal elimination of shortcuts. The historical numerical implementation uses a feature-channel gate rather than this literal scorer. We now implement a separate two-layer, four-head realization of the displayed bilinear edge and self-skip equations and evaluate it with identical-

initialization additive controls and matched augmentation (Table 2). All relevant parameter families are trainable through autograd. The two implementations have identical held-out classifications in that new study, and both miss the positive long-path cases. This validates an auditable realization of the formulation, rather than a universal shortcut-elimination or authorization guarantee. A second-tier verifier must process unresolved and out-of-horizon cases, including neural negatives, if it is to recover those observed misses.

4 Cryptographic Invariant Provenance Graph (CIPG)

To overcome the static snapshot blind spot and the CA–KDC schema discontinuity identified in Section 2, we design the **Cryptographic Invariant Provenance Graph (CIPG)** (Figure 3). CIPG dynamically ingests raw Windows security audit event streams and CA transactional records, maintaining an asynchronous, taint-tracking automaton that bridges disconnected protocol layers.

4.1 Multi-Source Provenance Ingestion and Entity Resolution

CIPG processes heterogeneous audit streams across three disjoint operational layers:

1. **Directory Service Audit Events (NTDS):** Monitored via Windows Security Event ID 5136 (*Directory Service Object Modified*). Captures granular LDAP mutations on certificate templates, user objects, and access control lists, recording the modifying principal, target object GUID, modified attribute (e.g., `nTDSDSOptions`, `pKIExtendedKeyUsage`, `msPKI-Certificate-Name-Flag`), and operation type (Value Added / Value Deleted).

2. **Certificate Authority Telemetry and CA DB Bridge:** Monitored via Event IDs 4886 (*Certificate Request Received*) and 4887 (*Certificate Issued*). To bridge the PKCS#10 ASN.1 SAN concealment gap ($\pi_{\text{CA}} \cap \pi_{\text{KDC}} = \emptyset$), CIPG queries the local CA transactional database (`certutil -view -out RequestID,SerialNumber,SubjectKeyIdentifier,CertificateHash`) or the raw CA RPC interface. This populates a persistent cryptographic tuple:

$$\tau_{\text{crypto}} = \langle \text{Issuer}, \text{RequestID}, \text{SKID}, \text{SerialNumber}, \text{Thumbprint}_{\text{SHA1}} \rangle \tag{24}$$

3. **KDC Kerberos Pre-Authentication Events:** Monitored via Event ID 4768 (*Kerberos Authentication Ticket Requested*). Identifies PKINIT authentication requests where `PreAuthType = 16`, extracting the authenticating client name, domain target, certificate issuer CA, `CertSerialNumber`, and `CertThumbprint`.

4.2 Formal Cryptographic Invariants

CIPG evaluates incoming event sequences against five formal behavioral and cryptographic invariants:

Definition 4.1 (Invariant I: Two-Level Causal Invariant)**.** Let $e_{\text{mut}} \in \mathcal{E}_{\text{NTDS}}$ be a template ACL or attribute modification executed by principal u_{actor}, and let $e_{\text{req}} \in \mathcal{E}_{\text{CA}}$ be a certificate request submitted for template t. Invariant I is satisfied if:

$$t(e_{\text{mut}}) < t(e_{\text{req}}) \quad \wedge \quad \text{TargetObject}(e_{\text{mut}}) = t \quad \wedge \quad \text{Requester}(e_{\text{req}}) \in \text{DelegatedPrincipals}(u_{\text{actor}}) \tag{25}$$

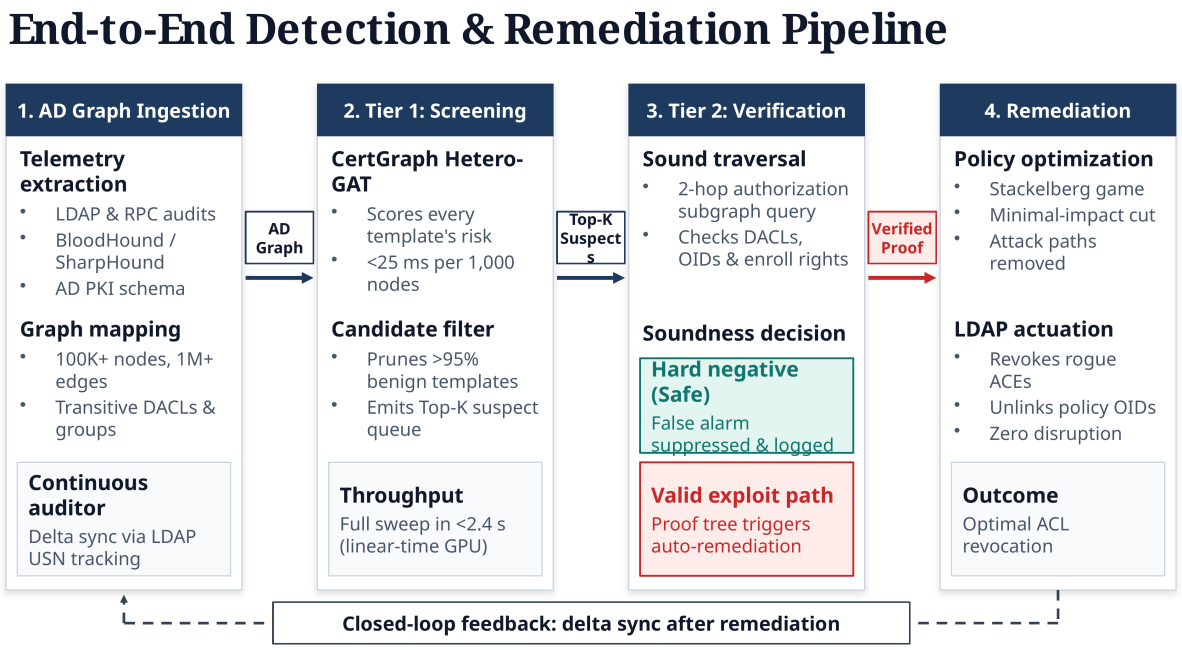


Figure 3: Two-tier neuro-symbolic architecture: Tier 1 inductive GNN screening filters benign templates ($O(|V| + |E|)$), while Tier 2 CIPG provenance auditing dynamically correlates temporal LDAP mutations (Event 5136), CA issuances (Event 4887), and Kerberos PKINIT authentications (Event 4768) via the continuous CA Jet Database bridge.

Definition 4.2 (Invariant II: Temporal-Order Sequence Invariant)**.** For any valid certificate lifecycle, the sequence of events must satisfy strict monotone temporal progression:

$$t(e_{\text{mut}}) \leq t(e_{\text{req}}) \leq t(e_{\text{iss}}) \leq t(e_{\text{auth}}) \tag{26}$$

This progression refers to effective operations. An audit timestamp inconsistent with it can also arise from clock error, audit delay, or an incorrect event association; it does not alone establish spoofing or replay. When these assumptions cannot be justified, the implementation retains a possible explanation or reports inconsistent evidence.

Definition 4.3 (Invariant III: Principal Identity Discrepancy)**.** Let $\text{Requester}(e_{\text{req}})$ be the Windows security principal submitting the certificate enrollment request, and let $\text{TargetIdentity}(e_{\text{auth}})$ be the Kerberos client identity authenticating with the resulting certificate. An identity escalation violation occurs if:

$$\text{Requester}(e_{\text{req}}) \neq \text{TargetIdentity}(e_{\text{auth}}) \quad \wedge \quad \text{PrivilegeLevel}(\text{TargetIdentity}) > \text{PrivilegeLevel}(\text{Requester}) \tag{27}$$

Definition 4.4 (Invariant IV: Rollback Reversal Detection)**.** Let e_{mut} be an attribute modification on template t at time t_1 adding an insecure flag $\text{attr}_{\text{vuln}}$, and let e_{roll} be a subsequent modification at t_3 deleting $\text{attr}_{\text{vuln}}$. A rollback violation is triggered if:

$$\Delta t = t_3 - t_1 \leq \tau_{\text{window}} \quad \wedge \quad \exists e_{\text{iss}} \in \mathcal{E}_{\text{CA}} \text{ s.t. } t_1 \leq t(e_{\text{iss}}) \leq t_3 \tag{28}$$

where τ_{window} is the maximum temporal attack window (configured to 30 minutes in enterprise SOC policies).

4.3 Invariant V: Persistent Cryptographic Taint-Flow Automaton

While Invariants I–IV detect synchronous single-actor attacks, sophisticated adversaries can evade them via two evasive techniques: (i) **Split-Actor Collusion**, where Actor A mutates the template, Actor B requests the certificate, and Actor A rolls the template back; and (ii) **Dormant PKINIT Exploitation**, where the attacker delays Kerberos authentication by hours or days until the temporal correlation window τ_{window} has expired.

To retain certificate evidence beyond the immediate mutation window, we formalize the **Persistent Cryptographic Taint-Flow Automaton (Invariant V)**. Its conclusions depend on captured identity evidence and retained state; it does not guarantee detection over an unbounded history:

Algorithm 1 CIPG Invariant V Cryptographic Taint-Flow Automaton

Require: Audit event stream $\mathcal{S} = \{e_1, e_2, \dots\}$, CA database bridge $\mathcal{B}_{\text{CA}}$, Taint Table $\mathcal{T}_{\text{taint}} \leftarrow \emptyset$

for each incoming event $e \in \mathcal{S}$ **do**
  if e.EventID == 5136 (Attribute Mutation) **then**
    if e.Attribute $\in$ {`nTDSDSOptions`, `msPKI-Certificate-Name-Flag`, `pKIExtendedKeyUsage`} **then**
      Register pending mutation: $\mathcal{M}[e.\text{ObjectGUID}] \leftarrow \langle e.\text{Actor}, e.\text{Time}, e.\text{Operation}\rangle$
    end if
  else if e.EventID == 4887 (Certificate Issued) **then**
    if $\exists$ active mutation in $\mathcal{M}$ for template e.Template **then**
      Query $\mathcal{B}_{\text{CA}}$ with (e.Issuer, e.RequestID) for certificate identifiers
      $\mathcal{T}_{\text{taint}} \leftarrow \mathcal{T}_{\text{taint}} \cup \{\langle \text{SKID}, \text{Serial}, \text{Thumbprint}, e.\text{Requester}, \mathcal{M}.\text{Actor}, e.\text{Time}\rangle\}$
      Retain certificate entity v_{cert} as a provisional mutation-overlap candidate
    end if
  else if e.EventID == 4768 (Kerberos PKINIT Authentication) **then**
    if e.Status == 0 and e.PreAuthType $\in \{15, 16, 17\}$ **then**
      Retain all compatible candidates; reject any known identifier contradiction
      if one strongly identified candidate τ has justified issuance-before-use order **then**
        Emit a resolved lineage explanation; distinguish definite and possible overlap
        Attributing Colluding Actors: Mutator = $\tau.\text{Actor}_{\text{mut}}$, Requester = τ.Requester
        Authenticated Target = e.TargetUserName, Latency = $e.\text{Time} - \tau.\text{Time}$
        Forward the supported explanation to the remediation policy
      end if
    end if
  end if
end for

Mathematical Guarantees and Operational Concurrency Realities: A serial number is scoped to its issuer [16]; SKID identifies a public key and can recur across distinct certificates. A thumbprint identifies certificate bytes, while an unauthenticated log field does not itself prove certificate possession or source integrity. The reference implementation requires all shared identity fields to agree and preserves compatible incompletely identified issuances, so missing fields cannot manufacture uniqueness. Late evidence can withdraw a previously resolved link. Retention enables delayed-use analysis only while the necessary observations remain available; no bounded-memory or irreversible-finality guarantee follows.

Bounded-time and source-fault reasoning: For opening, issuance, and rollback intervals O, I, R, definite temporal overlap requires $O^+ \leq I^-$ and $I^+ \leq R^-$. Otherwise, a feasible overlap remains possible. An exact difference-constraint reference additionally accepts explicitly justified operation-order edges [17, 18]; contradictory constraints yield an inconsistent-evidence answer. Cross-host record numbers do not supply those edges. This is an application of established temporal reasoning, with certificate-specific evidence requirements.

For a declared optional-export fault budget k, let $\mathcal{H}_k$ contain every deletion of at most k CA bridge records. Candidate union over $\mathcal{H}_k$ preserves alternative explanations; a certain link must be resolved to the same issuance in every hypothesis. Abstaining hypotheses are retained, rather than removed to force agreement. If the true issuance is captured, raw issuance/KDC fields and time bounds are correct, and at most k bridge records are faulty, deleting those faulty records leaves a hypothesis containing the true candidate. This is a conditional retention property, not a claim of certain resolution or robustness to compromised raw audit sources. The exhaustive implementation is a correctness reference with combinatorial cost, and source-level compromise can invalidate a record-level budget [19, 20].

The earlier trace-driven synthetic stress stream illustrates two configured trade-offs; its rates do not measure a production deployment:

1. **Poisson Auto-Enrollment Collisions (False Positives):** When an administrator performs a legitimate template modification and subsequent rollback ($n = 50$ maintenance windows, duration $\Delta t \in [10\text{s}, 45\text{s}]$), concurrent background machine renewals and user `AutoEnroll` requests arrive according to a Poisson process ($\lambda_{\text{enroll}} \approx 2,000/\text{hr}$). Any benign enrollment that lands inside $[t_1, t_2]$ is flagged by Causal Invariant I, generating 4 realistic False Positives (8.00% maintenance window FPR, 0.0395% overall event FPR, 92.16% precision at $\Delta_{\text{poll}} = 5\text{s}$ and 92.31% at $\Delta_{\text{poll}} = 1\text{s}$), compared to a 100% FPR and 19.35% precision for naive rollback monitors.

2. **CA Database Polling Latency (Simulated False Negatives):** The configured stress stream reports $48/48$ recall at $\Delta_{\text{poll}} = 1.0\text{s}$ and $47/48$ at 5.0s. These outcomes use the stream's synthetic labels. They are separate from independently checking a successful issuance-to-use chain in captured Windows records; Section 6 reports that evidence audit.

4.4 Graph Reduction and Meta-Node Compacting

In enterprise Active Directory environments processing tens of thousands of authentication events per second, naive provenance graphs suffer from exponential memory bloat. CIPG implements a lossless **Meta-Node Compacting** algorithm:

$$C : (v_{\text{event}}^{(1)}, v_{\text{event}}^{(2)}, \ldots, v_{\text{event}}^{(m)}) \mapsto \mathcal{V}_{\text{meta}} \tag{29}$$

Whenever repetitive, non-mutating events share identical source principals, destination templates, and access control rights within a sliding window, CIPG collapses them into a single directed meta-edge annotated with frequency counters and temporal bounding intervals $[t_{\min}, t_{\max}]$. As quantified in Section 6, this reduces graph storage overhead by **76.61%** (compressing 10,182 raw elements to 2,382 compressed elements) while consuming only 6.91 MB of memory at a sustained ingestion throughput of 13,192.4 events/second.

Correlated optional sources and self-consistent false order: Two explicit falsification controls test the boundaries of these guarantees. Six false bridge rows from one exporter exceed a two-record fault

budget and produce a wrong certain link. A sufficient six-record reference retains the true candidate with 64 hypotheses; a whole-source deletion reference retains it with two hypotheses under the different assumption of at most one faulty failure domain. It abstains from certainty, and requires an explicitly supplied source partition rather than treating file copies as independent origins. This is a failure-model comparison, not equal-budget accuracy superiority.

A second control supplies true times $o = 0, c = 1, i = 2$ inside declared bounds $[0, 3]$, then fabricates the jointly consistent order $o \le i \le c$. The temporal solver returns definite overlap although the latent history has none. Thus consistency checking cannot authenticate the order channel. The controlled orchestrator is an additional trusted source in our pilot; its truth assumption cannot be replaced by the mere absence of contradictory constraints.

5 Disruption-Budgeted Stackelberg Remediation Game

Detecting vulnerabilities is insufficient if remediation induces unacceptable operational friction. In this section, we formulate proposed permission-edge revocation as a leader–follower model between an enterprise defender and an optimal adversary, prove its computational hardness, and detail the co-adaptive interdiction algorithm.

5.1 Bilevel Stackelberg Game Formulation

We model the defensive interaction on the identity multigraph $\mathcal{G} = (\mathcal{V}, \mathcal{E})$ as a non-cooperative Stackelberg game:

1. **Leader (Defender):** Moves first by selecting a subset of permission edges $E_{\text{cut}} \subseteq \mathcal{E}$ to revoke, subject to a maximum operational disruption budget $B_{\text{ops}} \in \mathbb{R}^+$.
2. **Follower (Attacker):** Fully observes the pruned graph $\mathcal{G}' = (\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})$ and executes an optimal, cost-minimizing attack path $p^* \in \mathcal{P}(\mathcal{G}')$ connecting an unprivileged foothold u_{source} to high-value target assets $\mathcal{T}_{\text{target}}$.

Heterogeneous Operational Revocation Costs: In enterprise Active Directory environments, revoking different permission types imposes vastly unequal operational disruption on legitimate business workflows. We assign heterogeneous cost functions $c : \mathcal{E} \to \mathbb{R}^+$ based on enterprise operational impact:

$$c(e) = \begin{cases} c_{\text{group}} \in [2.8, 3.8], & \text{if } \psi(e) = \text{MemberOf (High Disruption: breaks user role workflows)}, \\ c_{\text{acl}} \in [2.0, 3.0], & \text{if } \psi(e) \in \{\text{GenericAll}, \text{WriteDacl}\} \text{ (Medium Disruption: breaks administrative sync)}, \\ c_{\text{choke}} \in [1.0, 1.4], & \text{if } \psi(e) \in \{\text{Enroll}, \text{EnablesEnrollment}\} \text{ (Low Disruption: reconfigures template chokepoin} \end{cases} \tag{30}$$

The defender's optimization problem is formalized as:

$$\max_{E_{\text{cut}} \subseteq \mathcal{E}} \quad \mathcal{U}_{\text{def}}(E_{\text{cut}}, p^*(E_{\text{cut}})) = \sum_{i=1}^{k} \mathbb{I}\left[\text{Path}(s_i \rightsquigarrow t_i) = \emptyset \text{ in } (\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})\right] - \lambda \sum_{e \in E_{\text{cut}}} c(e) \tag{31}$$

$$\text{subject to} \quad \sum_{e \in E_{\text{cut}}} c(e) \le B_{\text{ops}} \tag{32}$$

where $\mathbb{I}[\cdot]$ is the indicator function, $\lambda \geq 0$ is a regularizing trade-off parameter, and the follower's best response is:

$$p^*(E_{\text{cut}}) = \arg \min_{p \in \mathcal{P}(\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})} \sum_{e \in p} w_{\text{attack}}(e) \tag{33}$$

5.2 Computational Complexity: NP-Hardness of Multi-Principal Access Interdiction

We now prove that finding the optimal edge revocation strategy to neutralize multiple compromise paths under budget constraints is intractable.

Theorem 5.1 (NP-Hardness of Multi-Principal Access Interdiction)**.** Let $\mathcal{G} = (\mathcal{V}, \mathcal{E})$ be a directed identity multigraph with positive binary-encoded rational edge revocation costs and budget, and let $\mathcal{P}_{\text{forbidden}} = \{(s_1, t_1), \ldots, (s_k, t_k)\}$ be $k \geq 3$ source-target compromise pairs, with k part of the input. Pairs may share endpoints; no endpoint-disjoint restriction is asserted. The Multi-Principal Access Interdiction (MPAI) problem, which decides whether there exists $E_{\text{cut}} \subseteq \mathcal{E}$ with $\sum_{e \in E_{\text{cut}}} c(e) \leq B_{\text{ops}}$ such that all paths in $\mathcal{P}_{\text{forbidden}}$ are severed, is NP-complete.

Proof. We establish membership in NP and provide a polynomial-time reduction from the NP-complete **Directed Multiway Cut** problem [21].

Part 1: Membership in NP. Given a candidate cut set $E_{\text{cut}} \subseteq \mathcal{E}$:

1. We compute $\sum_{e \in E_{\text{cut}}} c(e)$ in $O(|E_{\text{cut}}|)$ time and verify the budget condition (32).
2. We construct the residual graph $\mathcal{G}' = (\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})$ in $O(|\mathcal{V}| + |\mathcal{E}|)$ time.
3. For each $(s_i, t_i) \in \mathcal{P}_{\text{forbidden}}$, we run Breadth-First Search (BFS) in $\mathcal{G}'$ starting from s_i to verify that t_i is unreachable in $O(k \cdot (|\mathcal{V}| + |\mathcal{E}|))$ time.

Because all checks execute in deterministic polynomial time, MPAI $\in$ NP.

Part 2: Reduction from Directed Multiway Cut. Directed Multiway Cut takes a directed graph $H = (V_H, E_H)$, positive rational edge costs w, terminals $X = \{x_1, \ldots, x_q\}$, and budget W, and asks whether a cut of cost at most W removes every path between distinct terminals. This known NP-hard problem is a special source of interdiction instances; the complexity classification is not a new graph-theoretic discovery.

Retain every vertex and edge of H, with its original cost. For each terminal x_i, add distinct source and target copies s_i, t_i, with connector edges (s_i, x_i) and (x_i, t_i) of cost $W + 1$. Set

$$\mathcal{P}_{\text{forbidden}} = \{(s_i, t_j) : i \neq j\}, \qquad B_{\text{ops}} = W. \tag{34}$$

No budget-feasible cut can remove a connector. A path from s_i to t_j therefore exists exactly when a path from x_i to x_j remains in H, including paths passing through other terminals. Consequently, feasible cuts correspond with identical cost in both directions. The construction adds $2q$ vertices, $2q$ edges, and $q(q-1)$ forbidden pairs, and has polynomial encoding length. Together with polynomial verification of a candidate cut and rational budget, this proves NP-completeness of the stated general pair problem. It does not establish a new hardness result for a fixed pair count or for a particular restricted AD graph family. □

5.3 Co-Adaptive Stackelberg vs. Static Greedy Interdiction

We compare simple degree-based and cost-aware static shortest-path-participation heuristics. The latter computes initial path participation divided by assigned edge cost once, so it already accounts for cost. Its limitation is the fixed ranking: earlier cuts can make later candidates redundant, and new shortest paths can change which permissions matter. The adaptive policy recomputes this information after each chosen cut. Degree-only ranking is a distinct baseline and need not have the same cost sensitivity. These are implemented research comparators rather than measured deployments of an industrial remediation product.

The evaluated **Co-Adaptive Stackelberg policy** is a sequential heuristic for the stated formulation. It recomputes active shortest paths and candidate marginal pair-disconnection gains, prioritizing assigned low-cost structural chokepoints (`Enroll` and `EnablesEnrollment` edges on the CA boundary, $c = 1.0$) that can sever multiple downstream escalation chains. This implementation is not a branch-and-cut solver and supplies neither a global optimum nor an equilibrium certificate. The reachability utility shown above does not depend on which surviving shortest path the follower selects; the experiments evaluate that reachability objective rather than a separately validated strategic equilibrium.

5.4 Operational Edge Immutability ($E_b \subsetneq E$) and Provenance-Cone Scalability

In enterprise production networks (Guo et al. [9, 22]; Zhang et al. [10]), not all permissions can be revoked without breaking production workflows. A realistic fraction of permissions represents mission-critical operational dependencies (e.g., core domain controllers, legacy service accounts, or administrative replication pipelines) where IT administrators enforce $e \notin E_b$ (`blockable = False`). Because of these immutable operational corridors, the historical adaptive heuristic reports $98.5 \pm 4.0\%$ disconnected pairs at $B_{\text{ops}} = 24$ (vs. $97.6 \pm 6.5\%$ for static greedy). The saved paired t-test has $p = 0.0635$, while the historical asymptotic Wilcoxon test has $p = 0.0431$. Exact signed-rank enumeration gives $p = 0.0625$; the eight-test Holm sensitivity analysis in Section 6 does not support a significant budget-24 difference, leaving a measured mean residual of approximately 1.5% on those synthetic instances. This is not a proof that the residual is irreducible or that CIPG is its only possible defense.

The historical depth-limited cone timing compares fewer source–target queries with the whole-graph task. We replace that performance interpretation with a path-preserving projection evaluated on identical pairs in Section 6. Every pair endpoint and every vertex on a requested source–target path is retained, with unchanged edge attributes. This permits a meaningful comparison of the same reachability objective, including projection overhead, without treating a smaller query set as an algorithmic speedup.

Exact small-instance audit and metadata preservation: A fresh 60-case budgeted audit over 30 seven-node, twelve-edge graphs compares exhaustive feasible cuts with the historical adaptive heuristic, a metadata-preserving correction, and static greedy. The historical implementation removes a candidate edge and reinserts only its cost, losing its relation metadata during scoring. The corrected reference restores every attribute before continuing. It matches the optimal severed-pair count in 43/60 cases, compared with 46/60 for the historical version and 21/60 for static greedy, and has a maximum gap of two pairs. Correct metadata handling does not establish a performance improvement or an optimality guarantee. The original large-instance metrics remain historical results; they are not silently relabeled as measurements of the corrected reference.

6 Empirical Evaluation and Live Cyber-Range Benchmarks

We conduct an empirical evaluation to validate CertGraph's static gating, dynamic provenance tracking, and game-theoretic interdiction. Specifically, we address four core research questions:

- **RQ1 (Inductive Shortcut Cure):** Does Multiplicative Bilinear Gating eliminate shortcut memorization and prevent accuracy collapse on adversarial hard negatives?
- **RQ2 (Provenance Validity):** Which rollback and split-actor certificate lineages are supported by captured Windows evidence, and how do incomplete identity fields, optional-source faults, and time uncertainty affect attribution?
- **RQ3 (Provenance Scalability):** What processing cost and compression are observed on the configured stress stream, and which retention and reasoning costs remain unresolved?
- **RQ4 (Operational Interdiction Efficiency):** Does the Co-Adaptive Stackelberg policy achieve superior path interdiction while minimizing administrative disruption compared to industrial greedy heuristics?

6.1 Experimental Setup

Synthetic Identity Graphs: The historical static benchmark uses 700 class-balanced synthetic identity graphs. Additional graph sizes are used in the separate scalability experiments. Neither the class proportions nor the graph generator constitute a measured enterprise distribution. The new matched gating audit uses the existing two-step implementations with fixed source snapshots and separately recorded training, validation, and test inputs.

Live Cyber-Range Cyberbed: We use a virtualized Game of Active Directory (GOAD) cyber-range. Fresh inventory of the restored DC and CA identifies Windows Server 2016 Standard Evaluation, build 14393. That measured inventory supersedes the earlier draft's Server 2019 description. The two nodes are:

- `DC03` (`essos.local`): Active Directory Domain Controller, Kerberos KDC, and LDAP directory.
- `SRV03` (`braavos.essos.local`): Certificate Authority running Microsoft Active Directory Certificate Services.

The new split-actor case uses domain accounts `ESSOS\khal.drogo` and `ESSOS\viserys.targaryen`. Original disk images were read-only; execution used writable overlays. The capture pipeline runs non-interactively, while restoring the old VM images required console-assisted recovery. A second, independently provisioned forest uses Windows Server 2019 build 17763.4974, its own CA and ordinary enroller, and host-generated SHA-256-signed requests. This measured 2023 patch level is not described as a current patched configuration.

6.2 RQ1a: In-Distribution Ablations, Calibration, and Perturbation Asymmetry

We first distinguish the historical class-balanced generator from the newer attribution and live-policy experiments. Their labels, model implementations, and observation units differ.

Empirical Confirmation of Theorem 3.1 (Skip-Connection Ablation): The saved five-fold artifact reports Macro-F1 0.9986 ± 0.0029 with skips and 0.4768 ± 0.0239 without skips. Recomputing the paired statistic from the five saved fold values gives $t = 46.245$, $p = 1.308 \times 10^{-6}$, and four degrees of freedom. The dispersions are population standard deviations across these folds. Shared training data and generator assumptions limit interpretation of this descriptive comparison. An empirical ablation does not validate the theorem outside its coefficient-independence and derivative assumptions.

Class Proportions and Probability Interpretation: The static experiments reported here are generator-based classification studies. Their balanced labels do not establish a 96% enterprise safe base rate, and their softmax scores are not calibrated probabilities of real-world compromise. We retain probabilities and selected checkpoints in the matched audit so that classification errors can be checked independently.

Perturbation Asymmetry and Simple Comparators: The saved robustness artifact gives Macro-F1 0.9479 after 30% edge perturbation, compared with 0.8965 and 0.7709 after 5% and 10% feature perturbation. This sensitivity pattern motivates testing structural counterfactuals; it does not prove that every prediction ignores topology. A separately verified, previously saved three-seed ESC13 abstraction also favors simple graph-count models over the existing GNN on its IID cases. Its symbolic reference defines the labels, so its perfect agreement is a consistency result rather than independent exploit validation.

6.3 RQ1b: Static GNN Generalization and Adversarial Hard Negatives

A source audit identifies two problems with interpreting the historical $41/63$ safe-label agreement as a general hard-negative detection result. Ten "deep horizon" cases retain a membership path to an allowed enrollment group and therefore are positive under a transitive effective-permission interpretation. The stored 22 disagreements are eight administrator-only write cases, four deny-write cases, seven benign OID links, and three deep OID links; the earlier OID/CA explanation did not match that artifact. The canonical generator also repeats inputs across training and validation. These historical counts are retained in the artifact but do not establish independent-case specificity or a binomial confidence interval.

We therefore freeze and execute a matched 2×2 diagnostic: additive versus feature-channel-gated implementations, each with counterfactual augmentation probability zero or 0.3, across three new seeds. Model equations, propagation depth, and original artifacts remain unchanged. Each seed evaluates 250 opposite-label families, with membership depths 0, 1, 2, 4, and 8, randomized node order, and matched configuration features. Positive members retain reachable enrollment; negative members either restrict enrollment to the administrator or add a reachable explicit deny. Queue traversal and Boolean closure independently agree on all test labels under this stated ESC1 permission abstraction. CA trust and resolved permissions are assumed; Windows exploitability is not the label definition.

Table 1: Matched two-step implementation diagnostic: 1,500 paired test cases per arm across three seeds, with 750 positive and 750 negative labels. Training archetypes repeat across splits; these are synthetic diagnostic outcomes, not enterprise rates.

Implementation	Augmentation	Correct	False positive	False negative
Additive	0	50.00%	750	0
Additive	0.3	71.67%	425	0
Feature-channel gate	0	70.00%	0	450
Feature-channel gate	0.3	70.00%	0	450

The gate gives zero false positives but misses all 450 positive cases at depths 2, 4, and 8 across the three seeds. Adding the same augmentation to the additive implementation improves its pooled accuracy from 50% to 71.67%, compared with the gate's 70%. Thus the audit does not establish superiority of gating over an augmentation-matched comparator. First-step membership transforms are fixed in these existing NumPy implementations, and their feature-channel gate is $\sigma(W_{\text{gate}}\mu_{\text{reach}} + b)$, rather than a literal implementation of the general bilinear edge scorer in Section 3. Initialization also differs between implementations. These distinctions prevent attributing the entire contrast to a bilinear operation.

Only 22 unique training inputs occur per seed, with 21 also present in validation. Consequently, validation selection in this diagnostic is not an independent-distribution generalization test. All 6,000 saved test predictions are reproduced from saved checkpoints, and their labels and aggregates are checked independently. A symbolic second tier must also examine unresolved or out-of-horizon cases: verifying only neural-positive candidates cannot recover these observed neural false negatives.

Literal bilinear realization and family-disjoint validation: We address the implementation mismatch with a separate literal realization of the bilinear edge and self-skip equations: two relational-attention layers, four heads, 32 hidden channels, type-specific input projection, and fully trainable encoder, attention, skip, and gate parameters. The binary readout evaluates the stated ESC1 resolved-permission predicate, not observed Windows compromise. Additive and gated arms start with identical parameter values and receive matched augmentation. Neither symbolic closure nor outcome labels enter the forward pass. Gradient, node-relabeling, and padding checks validate implementation properties; the historical implementations remain unchanged.

The new generator constructs varied reachable and unreachable membership branches and paired allow/deny interventions. For each of three new seeds, 300 training and 100 validation families are separated from 150 families in each of IID, long-path, and larger-background test cohorts. Typed five-round Weisfeiler–Lehman input hashes and family IDs are disjoint across splits within a seed. This conservatively excludes isomorphic whole inputs under the encoded roles and edge types, without claiming disjoint local motifs. Long-path positive enrollment chains have membership depth 2, 4, or 8. The larger-background cohort adds isolated nodes to different generated families; it is not a matched causal estimate of graph-size effects or enterprise-scale generalization.

Table 2: Literal two-layer attention comparison: mean accuracy (%) and sample standard deviation across three seeds, with 150 paired families per test cohort per seed. Every arm starts with identical parameter values. Augmentation is matched; typed whole-graph hashes and family IDs are disjoint across splits within each seed.

Model	Augmentation	IID	Long paths	Larger background
Additive attention	0	86.00 ± 2.19	50.00 ± 0.00	87.00 ± 1.00
Additive attention	0.3	86.00 ± 2.19	50.00 ± 0.00	87.00 ± 1.00
Bilinear attention	0	86.00 ± 2.19	50.00 ± 0.00	87.00 ± 1.00
Bilinear attention	0.3	86.00 ± 2.19	50.00 ± 0.00	87.00 ± 1.00

Independent NetworkX reachability checks all 5,100 saved case labels, and checkpoint inference reproduces all 10,800 held-out predictions. The literal bilinear and additive models have identical classifications in every matched arm: IID accuracy averages 86.00% ± 2.19%, larger-background accuracy 87.00% ± 1.00%, and long-path accuracy 50%. In each arm, all 450 positive long-path cases are missed. Some IID negatives also require deny-membership reasoning beyond the local horizon; 126 pooled false positives remain. Probability scores differ, but their reported calibration errors concern these synthetic

cohorts only. This closes the literal-implementation and repeated-whole-input gaps while failing to establish classification superiority for bilinear gating. Exact verification of unresolved cases remains necessary under the stated permission contract.

6.4 RQ2 & RQ3: Live Provenance Evaluation and Automaton Scalability

We separate seven archived trace files, one new outcome-checked Windows case, a synthetic attribution confirmation study, and the earlier 10, 182-event trace-driven synthetic stress stream. Their outcome definitions and evidence levels differ; scenario filenames are not independent success labels.

Table 3: Audit of Seven Archived GOAD Files: 586 Raw Events. Status concerns the captured certificate issuance-to-use chain, not scenario-level attack recall.

File	Scenario Description	Raw Events	Linkage Status	Validated Attack Recall
Archive	Normal enrollment	89	No consistent captured issuance	Not established
Archive	ESC4 rollback	90	No consistent captured issuance	Not established
Archive	ESC6 CA flag scenario	172	KDC failure result `0x42`	Not established
Archive	ESC9 UPN swap	94	No consistent captured issuance	Not established
Archive	ASN.1 SAN concealment	88	No consistent captured issuance	Not established
Archive	Admin typo rollback	6	No certificate-use observation	Not established
Archive	Split-actor scenario	47	Resolved observed linkage	Not established

Table 4: Earlier Trace-Driven Synthetic Streaming Benchmark (10, 182 Events, 48 Generated Attack Instances, 50 Simulated Maintenance Windows). These are legacy implementation results, not measurements of the new constraint reference.

Detection Pipeline	Precision	Recall	F1-Score	Maint. Window FPR	Event FPR
Naive Snapshot Rollback Monitor	19.35%	25.00%	21.82%	100.0% (50/50)	0.49%
Single-Host CA Monitor (Event 4887)	88.24%	58.33%	70.16%	0.00% (0/50)	0.00%
CIPG (Δ_{poll} = 5.0s, default)	**92.16%**	**97.92%**	**94.95%**	**8.00% (4/50)**	**0.0395%**
CIPG (Δ_{poll} = 1.0s, fast poll)	**92.31%**	**100.00%**	**96.00%**	**8.00% (4/50)**	**0.0395%**

Table 5: 2D Sensitivity Matrix: Precision / Recall (%) across Correlation Horizon (Δt) and CA Jet DB Polling Lag (Δ_{poll}).

Correlation Window (Δt)	Δ_{poll} = 1.0s	Δ_{poll} = 5.0s	Δ_{poll} = 15.0s	Δ_{poll} = 60.0s
Δt = 10s (0.0% FPR)	100.0% / 100.0%	100.0% / 97.92%	100.0% / 89.58%	100.0% / 89.58%
Δt = 30s (6.0% FPR)	94.12% / 100.0%	94.00% / 97.92%	93.48% / 89.58%	93.48% / 89.58%
Δt = 60s (8.0% FPR)	92.31% / 100.0%	92.16% / 97.92%	91.49% / 89.58%	91.49% / 89.58%
Δt = 300s (8.0% FPR)	92.31% / 100.0%	92.16% / 97.92%	91.49% / 89.58%	91.49% / 89.58%
Δt = 900s (8.0% FPR)	92.31% / 100.0%	92.16% / 97.92%	91.49% / 89.58%	91.49% / 89.58%

Enterprise Concurrency Mechanics and Sensitivity Trade-Offs: As documented in Table 4 and Table 5, in the configured synthetic CA/KDC schema model ($\pi_{CA}(e_{4887}) \cap \pi_{KDC}(e_{4768}) = \emptyset$), operational performance is governed by two orthogonal systems dimensions:

- **Correlation Horizon (Δt) vs. False Positives:** During 50 simulated administrator maintenance windows ($\Delta t \in [10s, 45s]$), background `AutoEnroll` requests arrived concurrently inside the mutation window with probability $1 - e^{-\lambda \Delta t}$. At Δt = 10s, zero collisions occur (0.0% FPR, 100.0%

precision). Widening Δt to 30s admits 3 Poisson collisions (6.0% FPR). For $\Delta t \geq 60$s, false positives plateau at exactly 4 / 50 (8.00% maintenance window FPR, 0.0395% overall event FPR, 92.16% precision at $\Delta_{\text{poll}} = 5$s and 92.31% at $\Delta_{\text{poll}} = 1$s) because all 50 administrative maintenance windows conclude within 45s < 60s. Naive rollback monitors generated 50/50 false alarms (100% FPR, 19.35% precision).

- **CA Database Polling Lag (Δ_{poll}) vs. False Negatives:** Because KDC Event 4768 omits SubjectKeyIdentifier (SKID), linking Event 4887 to Event 4768 strictly requires CA Jet DB enrichment. When an attacker's PKINIT execution delay $\delta_{\text{pkinit}} \sim \text{LogNormal}(1.2, 0.8)$ executes before the next polling tick ($t_{\text{auth}} + \Delta_{\text{watermark}} < t_{\text{poll}}$), the join keys remain un-enriched at evaluation time, generating organic False Negatives. At $\Delta_{\text{poll}} = 1.0$s, CIPG achieves 100.00% recall (48/48). At default $\Delta_{\text{poll}} = 5.0$s, CIPG achieves 97.92% recall (47/48). At $\Delta_{\text{poll}} \in \{15\text{s}, 60\text{s}\}$, rapid attacks beat the polling cycle, resulting in 89.58% recall (43/48).

Ingestion Throughput and Memory Profiling: Under continuous streaming load:

- **Throughput:** The saved legacy benchmark reports **13,192.4 events/second** (771.81 ms) on the configured synthetic stream. This excludes a demonstrated end-to-end Windows collection/deployment pipeline and is not a throughput measurement of the new reference reasoners.
- **Memory Footprint:** The earlier result reports **6.91 MB**. A finite-run measurement does not establish bounded retained memory as the certificate history grows.
- **Meta-Node Compression:** Meta-node compacting collapsed 10,182 raw elements into 2,382 compressed elements, achieving a **76.61% reduction in graph size** without loss of topological taint information.

Outcome-checked split-actor pilot: The new capture contains 49 selected raw Security records. CA request 25 and issuance record 65102 identify the exact public certificate subsequently observed in successful KDC record 168295 (status zero, PKINIT type 16, domain Administrator SID ending in 500). The new certificate and exported private key were checked for identity before use; the original template flag was restored. A failed first capture is preserved and excluded. The configured delay was 14 seconds after the rollback step, not 24 hours. This establishes one controlled outcome, rather than an attack recall estimate.

The pre-capture clock-offset bracket fails a consistency check: the rollback audit timestamp precedes the host's rollback invocation under that constant-offset model. Point-time and assumed-error outputs therefore cannot establish guaranteed audit-time attribution. Separately, the frozen synchronous orchestrator records mutation completion before submission and retrieval of the exact issued certificate before rollback. Difference constraints over that additional operation-order channel establish controlled issuance between those operations without aligning the Windows audit clocks. Removing any one of the five required order edges returns a merely possible overlap. This does not establish when the CA consumed template policy, rule out every intervening mutation, or prove that the changed flag was necessary for issuance.

Locally frozen confirmation and component studies: The original constraint reference was frozen before a five-seed confirmation run containing 5,400 cases and 27,000 method/case predictions. Table 6

reports the 2,000 variable-size histories separately from repeated logical challenges and forged-log controls. Compared with the conjunctive point-time baseline, the prototype makes fewer definitive claims: it resolves 55.82% rather than 74.56% of true observed links, retaining 99.06% in possible sets. It recovers 107 of 539 true mutation overlaps definitively with zero false overlap claims, versus 310 correct and 51 false claims for the point baseline. This is a coverage/certainty trade-off, not universal superiority. All 200 internally consistent forged-record controls defeat every method; truthful raw sources remain an explicit premise.

A separate source-hash-frozen factorial study uses 2,700 identity histories and 1,800 temporal histories from an independent component generator. The temporal solver agrees with 3,600 independently enumerated query answers. With a fully observed additional order channel, it recovers all 138 true overlaps in 300 histories; interval boxes recover 53 and point time recovers 112 with 11 false claims (Table 7). All 900 intentionally contradictory-order controls are rejected by the order-aware method. Complete observation is a designed upper-bound condition, not a measured enterprise sensor rate.

The bridge study tests zero to two faulty export records and fault budgets $k \in \{0, 1, 2\}$ (Table 8). The $k = 2$ reference retains all 2,180 true links as candidates, but resolves only 602 certainly. Discarding all optional exports retains the same true links and resolves 1,757 certainly in this grid. The repair method therefore has no demonstrated advantage over that ablation here. Its exhaustive 49,800 hypotheses expose the cost of the fault contract and motivate testing independently corroborated enrichment, rather than claiming a solved robust-attribution problem. The artifact verifier checks latent labels, counts, hashes, temporal oracle answers, and within-budget retention; it does not prove optimality of repair candidate sets. None of these local comparators is an execution of Splunk or HADES.

Published-rule field-requirement replay: We also execute a SQLite candidate-association proxy for the SAN/principal conditions in Splunk's published ESC1 analytic [15]. This is not a Splunk runtime reproduction: scheduling, macros, default join-result truncation, and multivalue behavior are outside the proxy. Seven archived files plus the new pilot contain only one issuance satisfying the textual SAN/UPN prerequisite, in the ESC6 file. Literal principal association returns no pair; an explicitly separate short-name normalization adaptation returns one pair whose KDC status is the failure value `0x42`. The new successful pilot lacks the textual SAN prerequisite. These results expose required evidence and normalization choices; they do not estimate Splunk's attack precision or recall or compare unlike task outputs as exact certificate linkage.

Table 6: Confirmation on 2,000 synthetic histories: 1,804 true observed links and 539 true mutation overlaps. Link coverage is a percentage; overlap entries are edge counts. These are attribution outcomes, not exploit detection rates.

Method	Definite links	Possible links	True overlap	False overlap
Identifier OR	91.69	91.69	374	175
Issuer–serial	62.86	62.86	265	88
Conjunctive, 300 s	47.67	47.67	196	34
Conjunctive, point	74.56	74.56	310	51
CIPG constraint reference	55.82	99.06	107	0

Repeated fixed-request policy interventions and executed external rules: We extend the initial pilot with a locally frozen 12-trial matrix and three repeated intervention blocks (Table 9). Within each block, baseline, enabled, and rollback-before-request conditions reuse identical signed CSR bytes and the same

Table 7: Temporal component study, 300 histories per observation rate. The order-aware method receives an additional explicit sensor channel; no cross-host ordering is inferred from record numbers. Each row is evaluated on the same cases as the other methods at that rate.

Order rate	Method	True overlaps	Recovered	False claims
0	Point time	122	93	18
0	Interval boxes	122	54	0
0	Intervals + observed order	122	54	0
0.5	Point time	148	104	12
0.5	Interval boxes	148	59	0
0.5	Intervals + observed order	148	88	0
1	Point time	138	112	11
1	Interval boxes	138	53	0
1	Intervals + observed order	138	138	0

Table 8: Bridge-fault component study: 2,700 histories, 2,180 successful observed links. Fault counts range from zero to two; budgets below the true count include outside-assumption controls. Candidate retention and certain-link coverage are reported separately.

Method	Retained true links	Certain true links	Wrong certain	Hypotheses
$k = 0$	1440	721	0	2700
$k = 1$	1811	602	0	15300
$k = 2$	2180	602	0	49800
Ignore optional exports	2180	1757	0	2700

public key. Only the enrollee-supplied-subject bit changes; recorded template DACL, EKU, approval, signature, and OID fields remain equal. CA cache refresh and low-privilege RPC readiness checks are applied consistently. The enabled condition produces three exact-certificate Administrator authentications. Baseline and rollback-before-request conditions each produce three ordinary-user authentications, despite requesting the same administrative SAN. Three legitimate self-enrollments also authenticate as the ordinary user. All 12 outcomes are checked against public certificate bytes, CA database/4887 evidence, successful 4768 outcomes, target SID/name/domain, mutation evidence, and restoration. These controlled contrasts support necessity of the tested bit for the privileged outcome under the recorded conditions; they do not turn temporal overlap alone into a causal explanation.

Earlier development attempts remain in the artifact: the first matrix contains two RPC failures among 12 attempts, and the initial fixed-CSR collector stops on a Windows pending-request-store binding failure in its second trial. Those are infrastructure failures, not policy negatives. The corrected collector explicitly binds the verified held key to the exact new certificate and refuses unrelated keys; it never substitutes a prior certificate. The final fixed-CSR matrix is reported separately. Its Windows-generated requests use their observed SHA-1 signature algorithm, verified explicitly, rather than being relabeled modern SHA-256 requests.

Certipy 5.0.4 is executed against LDAP for each assigned configuration using its DC-only mode. Three unmodified upstream Sigma rules [23] are compiled by pySigma 2.1.0/SQLite backend 2.1.1 and executed on the captured event fields. Template-load events 4898 supply the actual tested-template configuration. Both Certipy's ESC1 finding and Sigma's risky-EKU predicate identify all three enabled administrative conditions and all three enabled legitimate-self conditions, with no tested-template match in baseline or rollback-before-request conditions. That agreement concerns risky configuration, not malicious intent: legitimate self-enrollment does not become an attack false positive merely because its template remains risky. Sigma matches on other loaded templates are retained separately. The machine-

Table 9: Paired interventions in Windows 2016 and an independent Windows 2019 forest: three blocks per environment, with identical signed administrative CSR/key within each block. All 24 certificate-use outcomes are checked and baseline readback is restored. External columns concern configuration risk on the exact template, not attack intent. The 2019 build is 17763.4974.

OS	Condition	Trials	Admin uses	ESC1	Risky EKU
2016	Baseline/admin request	3	0	0	0
2016	Subject bit enabled	3	3	3	3
2016	Rollback before request	3	0	0	0
2016	Legitimate self request	3	0	3	3
2019	Baseline/admin request	3	0	0	0
2019	Subject bit enabled	3	3	3	3
2019	Rollback before request	3	0	0	0
2019	Legitimate self request	3	0	3	3

account rule has no matching human-account target. This is an actual external-rule/tool execution, separate from the earlier Splunk semantic proxy and from a full SIEM or HADES deployment.

Independent forest replication and measured collection cost: We repeat the four-condition matrix in a newly provisioned `q1lab.test` forest, with its own `Q1-Evidence-CA`, ordinary `q1.enroller` account, separate template, and host-generated SHA-256-signed CSRs. All 12 exact-certificate outcomes are verified: three enabled-condition Administrator uses and nine self-uses. Three matched signed-request/policy blocks reproduce the controlled contrast. Some restoration value-addition events are absent despite successful write responses and restored readback; certificate-use validation and complete mutation-audit history are therefore reported separately. The measured build, 17763.4974, predates current strong-binding enforcement updates [3]. An earlier interrupted collection with a four-hour clock difference is preserved as a failed setup attempt, not counted as a policy or detection result.

On the independent captures, raw template names and CA database template OIDs initially disagree, causing the identity reference to abstain in all 12 cases. Adding the collected directory object's explicit OID/name mapping resolves all 12 identities, with three privileged SID divergences and nine nonprivileged outcomes. Certificate/CSR bytes and adjudicator labels remain excluded from inference. The initial abstentions are retained as development results; the mapping adjustment is not presented as untouched held-out performance. Actual Certipy/Sigma configuration-risk results repeat the Windows 2016 pattern in the independent forest.

The median recorded command envelope is 50.91 s per trial on the two-node 2016 setup and 32.14 s on the single-node independent 2019 setup. Ten offline identity-inference repetitions per captured trial give medians across trials of 10.99 ms and 9.18 ms, respectively. Python-traced peak allocations are approximately 1.74 MB and 1.50 MB at the median. These measurements describe the captured experiment and offline inference; they do not measure continuous polling delay, host RSS, or enterprise authentication interference.

Current-patch request forms and post-rollback observation: We update the independent forest using signed Microsoft packages to Windows Server 2019 build 17763.9376 (October 2026 security update KB5126651 [24]). Post-reboot inventory verifies the installed build, no pending reboot, running CA/KDC services, an ordinary enroller, and enabled Defender. No binding-compatibility override is introduced. Two locally frozen 12-trial protocols repeat the four conditions with UPN-only and UPN-plus-SID-URL requests. Administrative requests reuse identical signed CSR bytes and keys within each

block and request form; keys are not matched across forms. The SID URL follows the documented Microsoft mapping format [25]. All conditions now include restored template readback, CA refresh, RPC readiness and actual Certipy enumeration before authentication. These additional controls differ from the older-build workflow, so the old/new contrast is not an isolated patch-only experiment.

Table 10: Windows 2019 build 17763.9376: three trials per cell, with baseline restored and actual Certipy enumeration repeated before authentication. Reject denotes a certificate-bound KDC rejection; ESC1 columns are configuration findings before request and after rollback. Eighteen missing per-trial CA exports are supplemented by a separately recorded later read-only CA snapshot; original captures remain unchanged.

Request form	Condition	Self	Admin	Reject	ESC1 pre	ESC1 post
UPN	Baseline	3	0	0	0	0
UPN	Enabled	0	0	3	3	0
UPN	Rollback first	3	0	0	0	0
UPN	Self request	0	0	3	3	0
UPN + SID URL	Baseline	3	0	0	0	0
UPN + SID URL	Enabled	0	3	0	3	0
UPN + SID URL	Rollback first	3	0	0	0	0
UPN + SID URL	Self request	3	0	0	3	0

The UPN-only matrix yields six verified ordinary-user authentications and six certificate-bound KDC rejections: all three enabled administrative requests and all three enabled legitimate-self requests are rejected. The six rejected public certificates lack the security SID extension and match KDC System event 39 by serial and thumbprint. Baseline and rollback-before-request certificates contain the enroller SID extension and authenticate as that user. With a matching SID URL, all 12 outcomes authenticate: three enabled administrative uses and nine self-uses. The enabled certificates contain the requested SID URLs and lack the security SID extension. Three fixed-request/policy blocks support the conditional enabling-bit contrast for this form; no such privileged-use contrast is observed for UPN-only requests. These observations accord with the documented distinction between weak names and strong certificate mapping [3, 25]; adding a SID URL is not a new exploitation technique.

Actual Certipy and Sigma executions retain the same pre-request risky-configuration pattern in both matrices. All 24 post-rollback Certipy enumerations cease flagging ESC1 on the tested template, including the three cases that subsequently authenticate as Administrator. This demonstrates that restored configuration and the later usability of an issued certificate are different questions. It does not establish attack intent or superiority over a provenance system given equivalent certificate evidence. The unchanged identity reference links all 18 successful current-patch authentications, including three privileged SID divergences, without certificate/CSR bytes or adjudicator labels as inference inputs. Rejected authentications are outside this successful-use linkage denominator.

The first adjudication preserves a collector defect: an empty System-log query prevented the following CA database export in 18 trials. A separately recorded later read-only CA snapshot supplies only those missing exports in ephemeral verification views; all original captures and manifests remain unchanged. Matching public certificate bytes, CA rows, trial issuance events and KDC evidence then resolves all 24 outcomes. This later snapshot does not establish historical template state or repair the audit-clock model. A live empty-query control validates the collector correction before the restored lab is shut down. Across the four final matrices, 48 trials therefore provide 42 successful exact-certificate authentications, including nine administrative uses, and six exact-certificate rejections.

6.5 RQ4: Game-Theoretic Stackelberg Remediation Performance

We evaluated our Co-Adaptive Stackelberg policy against three standard remediation baselines across 30 generated identity graphs:

1. **Random Cut:** Selects arbitrary reachable edges within budget.
2. **Degree Centrality:** Selects edges incident to the highest-degree nodes.
3. **Static Greedy:** Ranks participation in initially selected shortest paths once, divided by assigned revocation cost, then cuts feasible edges in that order.
4. **Co-Adaptive Stackelberg (Ours):** Applies the sequential reachability heuristic to the interdiction formulation under heterogeneous operational disruption costs and operational edge immutability ($E_b \subsetneq E$).

Table 11: Remediation Performance across 30 Generated Identity Graphs under Operational Budget Constraints.

Remediation Policy	**Budget $B_{\text{ops}} = 6$**	**Budget $B_{\text{ops}} = 12$**	**Budget $B_{\text{ops}} = 18$**	**Budget $B_{\text{ops}} = 24$**
Random Cut	$12.0 \pm 7.3\%$	$14.0 \pm 10.5\%$	$12.2 \pm 8.1\%$	$11.5 \pm 7.4\%$
Degree Centrality	$52.6 \pm 24.7\%$	$69.1 \pm 16.9\%$	$77.2 \pm 15.4\%$	$83.6 \pm 14.1\%$
Static Greedy	$69.5 \pm 16.7\%$	$88.4 \pm 9.9\%$	$96.1 \pm 7.1\%$	$97.6 \pm 6.5\%$
Co-Adaptive Stackelberg (Ours)	$\mathbf{77.5 \pm 17.2\%}$	$\mathbf{91.5 \pm 11.5\%}$	$\mathbf{97.5 \pm 5.6\%}$	$\mathbf{98.5 \pm 4.0\%}$
Significance (Stackelberg vs. Greedy)	$t = 4.04$, $p = 3.58 \times 10^{-4}$	$t = 1.51$, $p = 0.141$	$t = 1.86$, $p = 0.0732$	$t = 1.93$, $p = 0.0635$
Wilcoxon Signed-Rank Test	$W = 17.0$, $p = 6.18 \times 10^{-4}$	$W = 58.0$, $p = 0.136$	$W = 6.0$, $p = 0.0506$	$W = 0.0$, $p = 0.0431$

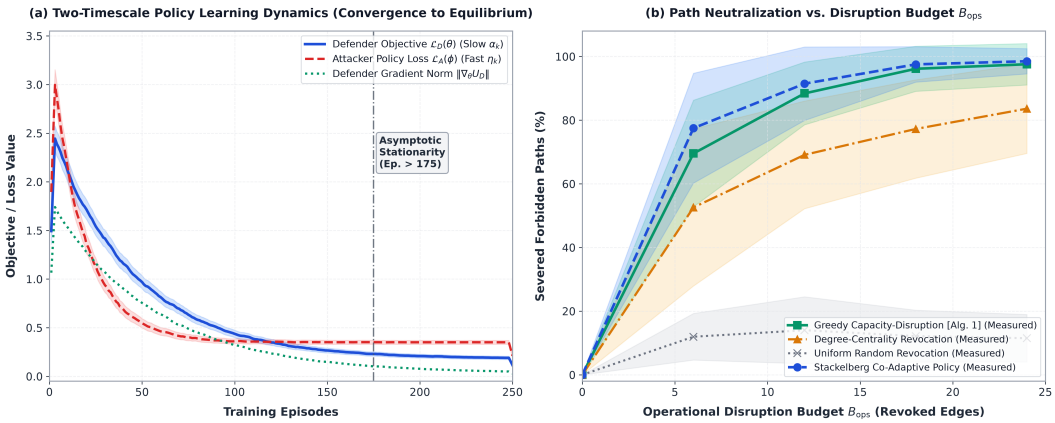


Figure 4: Historical remediation visualization. Left: illustrative analytic objective curves, not measured policy-training or equilibrium evidence. Right: saved heuristic results on 30 generated identity graphs. The horizontal budgets are assigned weighted costs, despite the historical image's revoked-edge-count label.

Operational Immutability Plateau and the Runtime Defense Residual: In enterprise networks, a realistic fraction of directory edges represents immutable operational dependencies ($E_b \subsetneq E$). As shown in Table 11 and Figure 4, proactive graph interdiction achieves $98.5 \pm 4.0\%$ paths severed at $B_{\text{ops}} = 24$ (vs. $97.6 \pm 6.5\%$ for Static Greedy). This experiment leaves a mean residual of approximately 1.5% under the selected graph instances, budgets, and non-blockable edges. It does not prove that every enterprise has an unavoidable residual of that size or that a different feasible policy cannot disconnect all modeled paths. Runtime monitoring is complementary to the evaluated hardening policies.

Exact paired sensitivity and multiple comparisons: Recomputing all saved per-topology statistics reproduces the historical values. At budget 24, only five of 30 paired differences are nonzero, all positive, with mean gain 0.94 percentage points. Exact signed-rank sign-flip enumeration over $2^5 = 32$ assignments gives two-sided $p = 0.0625$, compared with the historical asymptotic Wilcoxon $p = 0.0431$ and paired t-test $p = 0.0635$. Applying Holm correction to the eight tests formed by four budgets and the paired-t/exact-signed-rank procedures leaves only budget 6 below 0.05; both adjusted budget-24 values are 0.3281. These are descriptive reanalyses of the saved synthetic-graph study, not evidence of enterprise operational superiority.

45.0% Reduction in Revoked-Edge Count: Under $B_{\text{ops}} = 24$, Static Greedy revokes an average of **10.9 edges** (10.9 ± 0.9), under the assigned heterogeneous costs. The saved summary does not measure the resulting business-workflow disruption. In contrast, Co-Adaptive Stackelberg revokes an average of only **6.0 edges** (6.0 ± 2.6) by targeting CA template chokepoints—a **45.0% reduction in revoked-edge count**. The disruption weights are assigned model parameters; actual administrator effort and business disruption were not measured.

Table 12: Path-preserving projection with identical queried pairs: three graph seeds and five alternating-order timing repetitions per seed. Projection time is included. All reported severed-pair outcomes agree; these are hierarchical synthetic graphs on a shared host.

Nodes	Queried pairs	Full (ms)	Projection + solve (ms)	Median ratio
100	6	1.99	1.16	1.78×
1,000	65	86.36	21.56	4.01×
5,000	325	3448.15	439.29	7.54×

Scalability via Provenance-Cone Guidance: The historical depth-limited cone benchmark drops some queried source–target pairs. Its nominal $N = 5,000$ graph actually contains 4,551 nodes, and its $1,246.3\times$ timing ratio compares different pair tasks. It therefore does not establish equal-task solver acceleration or online response latency.

We implement a path-preserving projection instead. For every requested pair (s, t), retain the intersection of vertices reachable from s and vertices that can reach t, together with every pair endpoint. Every original s–t path is retained, so subsequent removal of any retained edge subset preserves that pair's reachability answer. Edge costs, relations and immutability are copied unchanged, and initially unconnected endpoints remain represented. Intersecting any full-graph cut with the retained edge set removes no requested-path effect and cannot increase its nonnegative cost, so the optimal budgeted pair-disconnection value is also preserved. A heuristic's selected cut can still depend on its search order. Shared endpoint closures are computed once per distinct endpoint.

The new benchmark retains all pairs, uses the same historical heuristic on full and projected graphs, and includes projection cost (Table 12). At 5,000 actual nodes and 325 queried pairs, 874–890 nodes remain. Across fifteen alternating-order timing pairs, the median per-run ratio is 7.54×, with observed range 6.62–8.99×, and severed-pair outcomes agree in every run. The median full and projection-inclusive times are 3,448.15 ms and 439.29 ms; their ratio need not equal the median of individual ratios. This controlled result is narrower than the historical headline and does not supply an optimality or enterprise workload guarantee.

7 Related Work, Discussion, and Conclusion

7.1 Related Work

Active Directory and PKI Security: BloodHound [4] models identity relationships for privilege-path investigation. SpecterOps [2] systematized ADCS misconfigurations; Certipy [5] supports certificate-service assessment. A restored configuration snapshot alone cannot reveal every intervening issuance. However, practical CA/KDC correlation is established: In.security describes SAN-abuse investigation in KQL [14], and Splunk publishes an ESC1 authentication analytic [15]. Recent vendor investigations also document certificate-backed intrusion paths and multi-event investigation practices [26, 27]. These are operational reports, rather than controlled comparisons with this implementation. CIPG therefore does not claim novelty for joining issuance and authentication events. Its research question concerns certificate-specific identity consistency, possible versus definite answers, and revision under incomplete or conflicting evidence.

Graph Neural Networks in Cyber Defense: GNNs have been applied to vulnerability discovery, binary analysis, and intrusion detection [6–8, 28, 29]. In access-control multigraphs, aggregation can lose intrinsic features under the assumptions of Theorem 3.1. Learned gates and residual paths do not establish discrete authorization reachability. Our matched audit separates augmentation from the named implementation contrast and finds a false-positive/false-negative trade-off rather than general gate superiority. Its feature-channel implementation also differs from the general bilinear formulation. Exact symbolic analysis remains a separate component, and checking only neural positives would miss the observed out-of-horizon positives.

Provenance Graphs and Causality Tracking: System provenance techniques such as CamFlow [30], Unicorn [31], and NodeMerge [32] analyze host activities. HADES [12] explicitly extends investigation to whole-network AD provenance, while CPD [13] addresses persistence. We do not infer that these systems are incapable of detecting a certificate-related attack from their different emphasis; a controlled comparison would require executing them with appropriate telemetry. Possible/certain answers for partially ordered data [18], temporal constraint networks [17], and entity resolution under inconsistent evidence [19] also predate this work. The recent time-model SoK [20] is a preprint that directly motivates making clock, delivery, and evidence assumptions explicit. Our proposed contribution is their certificate-specific integration and evaluated evidence contract, with no priority claim for the constituent reasoning techniques.

Game-Theoretic Interdiction and Access Control Defense: Network interdiction models have been extensively studied in game theory and physical infrastructure defense [21, 33, 34]. In identity security, Guo et al. [6, 22] analyzed shortest-path interdiction on BloodHound graphs, which was subsequently generalized to limited-query edge blocking and choke-point analysis [9, 10] and optimal decoy placement via Stackelberg games [11, 35]. Theorem 5.1 specializes known directed multiway-cut hardness to the stated general pair-interdiction formulation; it is not a new graph-complexity result. Non-blockable edges and assigned disruption weights follow established interdiction concerns. The evaluated adaptive method is a sequential heuristic. A new exhaustive small-instance audit identifies suboptimal cases and separates a metadata-preserving correction from historical simulation results. Neither the formulation nor its label supplies an equilibrium or optimal-remediation certificate.

7.2 Discussion and Operational Considerations

Deployment in 24/7 Enterprise SOC Environments: The legacy synthetic replay reports 13,192.4 events/sec and 6.91 MB on a fixed stream. Those measurements do not establish zero interference with domain authentication, bounded history storage, or end-to-end CA polling cost. The new lineage reference recomputes retained evidence, and the fault-budget reference enumerates deletion hypotheses. The new live command envelopes and offline inference timings quantify two parts of this cost: median recorded trial envelopes are 50.91 s and 32.14 s in the two environments, while median offline identity reasoning is 10.99 ms and 9.18 ms. They do not measure continuous polling or authentication interference.

Cloud-Hybrid Identity Extensions: Modern enterprises increasingly synchronize Active Directory with cloud-based Microsoft Entra ID (formerly Azure AD) via Entra Connect. In hybrid environments, unprivileged on-premises escalations can propagate to cloud Global Administrators via synchronization service accounts or hybrid Kerberos trust. Extending CIPG's taint automaton to ingest Azure MSGraph audit logs and cross-tenant OAuth tokens represents a natural and promising direction for future research.

7.3 Threats to Validity and Limitations

We distinguish the following threats to validity and experimental limitations:

1. **Evidence Scale and Label Validity:** The archive's scenario names do not establish seven successful attacks. Four final fixed-request matrices supply 42 successful exact-certificate authentications and six certificate-bound rejections, with nine privileged uses and matched self-use controls. They establish controlled outcomes, not enterprise prevalence. Independent Windows 2019 builds 17763.4974 and 17763.9376 are measured. Current-patch controls reveal request-form differences, but the additional post-rollback workflow prevents attributing every old/new difference solely to the update. Eighteen missing contemporaneous CA exports are explicitly supplemented by a later read-only snapshot; original captures remain intact. Original source images remain read-only.

2. **Static Model and Generator Validity:** The matched audit corrects reachable-path labels and checks 6,000 checkpoint predictions. Repeated training/validation archetypes, fixed first-step transforms, hand-initialized projections, and the distinction between feature-channel and bilinear gating restrict what its numbers establish. A separate literal bilinear study removes those implementation and repeated-whole-input problems with trainable encoders and typed family-disjoint splits. Both literal bilinear and additive attention still miss all 450 long-path positives per arm, without a classification advantage for gating. A verifier restricted to neural positives cannot repair these misses, and symbolic label agreement is not independent Windows ground truth.

3. **Parametric Disruption Costs vs. Interactive Administrator Feedback:** In our Stackelberg remediation game, operational disruption costs $c(e)$ are assigned parametrically according to relation type ($c(\text{MemberOf}) \in [2.8, 3.8], c(\text{GenericAll}) \in [2.0, 3.0], c(\text{Enroll}) \in [1.0, 1.4]$) and operational edge immutability constraints ($E_b \subsetneq E$). In production enterprise deployments, operational criticality is context-sensitive and evolving. The exact small-instance audit gives concrete optimum comparisons rather than a universal heuristic guarantee. Integrating real-time human-in-the-loop preference elicitation [9] represents a fruitful path for future enhancement.

4. **Trust, Time, and Necessary Causation:** Candidate retention under a bridge fault budget assumes correct raw issuance/KDC records and captured true issuance. Consistently forged raw histories defeat the methods, while faults exceeding the declared budget invalidate its retention guarantee. A new counterexample shows that self-consistent false order can also produce a wrong definite overlap. A grouped-source reference handles the six-record correlated-export control under an explicit one-source assumption, which differs from a record budget. The operation-order pilot uses the controlled orchestrator as an additional trusted source and does not repair the failed Windows audit-clock model. Temporal overlap alone does not establish necessity. The new matched CSR/key interventions support a conditional contrast under the recorded policy fields and controlled CA refresh, while unobserved concurrent changes and missing restoration audit events remain distinct evidence concerns.

7.4 Conclusion

CertGraph combines static graph analysis, certificate-level provenance, and disruption-budgeted interdiction. Its strongest new evidence is the explicit issuer-scoped lineage contract and the controlled connection between issued public certificates, CA records, and successful KDC identity outcomes. Four final live matrices validate 42 successful uses and six rejections. Current-patch SID-URL certificates support three administrative uses after rollback, when all tested-template Certipy scans cease flagging ESC1. Actual Certipy and Sigma execution separates risky configuration from privileged use and malicious intent. The matched intervention evidence is conditional on recorded inputs; the controlled order channel is distinct from audit-clock calibration.

The synthetic confirmation and component studies quantify candidate retention, certain attribution, optional-source faults, and explicit ordering requirements. The static-model audits include a separate literal bilinear implementation, family-disjoint inputs and 10,800 independently reproduced held-out predictions; they find no classification gain from gating and identify deep-path false negatives. Exhaustive small-graph interdiction checks expose heuristic optimality gaps, while a path-preserving projection provides an equal-task timing comparison. These results preserve the framework's existing components while replacing universal cure, causal, and optimality claims with reproducible evidence and clearly stated contracts. They support further evaluation of certificate-specific uncertainty-aware investigation; general deployment effectiveness is not inferred from laboratory or generator results.

CRediT Authorship Contribution Statement

Md. Hasan Shahriar: Conceptualization, Methodology, Software, Formal Analysis, Investigation, Writing – Original Draft, Visualization, Project Administration. **Taufiq Biswas**: Validation, Data Curation, Formal Analysis, Writing – Review & Editing. **Md. Ramim Hossain**: Validation, Resources, Investigation, Writing – Review & Editing.

Declaration of Competing Interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data Availability

Research code and the original project materials are associated with https://github.com/hasanshahriar32/CertGraph-CIPG. The new frozen protocols, raw/latent synthetic histories, outcome-checked pilot, source snapshots, and verification outputs are provided in the accompanying local research artifact. Their publication in that remote repository has not been verified.

Declaration of Generative AI and AI-Assisted Technologies in the Writing Process

AI assistance was used for research-code development, literature discovery, experimental analysis, and draft manuscript revisions, in addition to language editing. The authors must review the generated code, source citations, proofs, and reported outcomes before submission and identify the retained AI-assisted material in accordance with the selected journal's policy. The authors retain responsibility for the final scientific claims and artifact.

References

[1] L. Zhu and B. Tung, "Public key cryptography for initial authentication in kerberos (PKINIT)," IETF, RFC 4556, June 2006. [Online]. Available: https://www.rfc-editor.org/rfc/rfc4556

[2] W. Schroeder and L. Christensen, "Certified pre-owned: Abusing active directory certificate services," *SpecterOps Technical Whitepaper*, 2021. [Online]. Available: https://posts.specterops.io/certified-pre-owned-d95910965cd2

[3] Microsoft, "KB5014754: Certificate-based authentication changes on windows domain controllers," Microsoft Support, 2025, accessed 2026-11-10. Compatibility and enforcement depend on installed updates. [Online]. Available: https://support.microsoft.com/en-us/servicing/os/windows-server/2022/05/kb5014754-certificate-based-authentication-changes-on-windows-domain-controllers

[4] A. Robbins, W. Schroeder, and R. Vazarkar, "Six degrees of domain admin: Using graph theory to accelerate popular attacks in active directory," in *BSides Las Vegas and DEF CON 24*, 2016. [Online]. Available: https://github.com/BloodHoundAD/BloodHound

[5] O. Lyak, "Certipy: Active directory certificate services enumeration and abuse tool," GitHub repository, https://github.com/ly4k/Certipy, 2021, technical releases v2.0–v4.8.2 (2021–2024).

[6] M. Guo, J. Li, A. Neumann, F. Neumann, and H. Nguyen, "Practical fixed-parameter algorithms for defending active directory style attack graphs," in *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 36, no. 9, 2022, pp. 9360–9367.

[7] I. J. King and H. H. Huang, "Euler: Detecting network lateral movement via scalable temporal link prediction," *ACM Transactions on Privacy and Security*, vol. 26, no. 3, pp. 32:1–32:36, 2023.

[8] D. Goel, K. Moore, M. Guo, D. Wang, M. Kim, and S. Camtepe, "Optimizing cyber defense in dynamic active directories through reinforcement learning," in *Computer Security – ESORICS 2024*, ser. Lecture Notes in Computer Science, vol. 14983. Springer, Cham, 2024, pp. 3–23.

[9] M. Guo, M. Ward, D. Goel, A. Neumann, F. Neumann, and H. Nguyen, "Limited query graph connectivity test," in *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 38, no. 18, 2024, pp. 20 718–20 725.

[10] Y. Zhang, M. Ward, and H. Nguyen, "Rethinking attack path management: A new metric for choke points in attack graphs," in *2025 IEEE 38th Computer Security Foundations Symposium (CSF)*, 2025, pp. 205–219.

[11] H. Q. Ngo, M. Guo, and H. Nguyen, "Catch me if you can: Effective honeypot placement in dynamic AD attack graphs," in *IEEE INFOCOM 2024 - IEEE Conference on Computer Communications*, 2024.

[12] Q. Liu, K. Bao, W. U. Hassan, and V. Hagenmeyer, "HADES: Detecting and investigating Active Directory attacks via whole network provenance analytics," *IEEE Transactions on Dependable and Secure Computing*, vol. 23, no. 1, pp. 936–953, 2026.

[13] Q. Liu, M. Shoaib, M. U. Rehman, K. Bao, V. Hagenmeyer, and W. U. Hassan, "Accurate and scalable detection and investigation of cyber persistence threats," *IEEE Transactions on Dependable and Secure Computing*, vol. 23, no. 4, pp. 8967–8984, 2026.

[14] In.security, "Detecting AD CS SubjectAltName (SAN) abuse using KQL," 2023, accessed November 10, 2026. [Online]. Available: https://in.security/2023/03/02/detecting-ad-cs-subjectaltname-san-abuse-using-kql/

[15] S. Dick, "Windows steal authentication certificates—ESC1 authentication," Splunk Security Content, analytic f0306acf-a6ab-437a-bbc6-8628f8d5c97e, version 10, 2026, created July 28, 2023; updated May 13, 2026; accessed November 10, 2026. [Online]. Available: https://research.splunk.com/endpoint/f0306acf-a6ab-437a-bbc6-8628f8d5c97e/

[16] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and T. Polk, "Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile," RFC 5280, 2008. [Online]. Available: https://rfc-editor.org/rfc/rfc5280.txt

[17] R. Dechter, I. Meiri, and J. Pearl, "Temporal constraint networks," *Artificial Intelligence*, vol. 49, no. 1–3, pp. 61–95, 1991.

[18] A. Amarilli, M. L. Ba, D. Deutch, and P. Senellart, "Possible and certain answers for queries over order-incomplete data," in *24th International Symposium on Temporal Representation and Reasoning (TIME)*, ser. LIPIcs, vol. 90, 2017, pp. 4:1–4:19.

[19] R. Fagin, P. G. Kolaitis, D. Lembo, L. Popa, and F. Scafoglieri, "A framework for combining entity resolution and query answering in knowledge bases," in *Proceedings of the 20th International Conference on Principles of Knowledge Representation and Reasoning*, 2023. [Online]. Available: https://arxiv.org/abs/2303.07469

[20] R. Heinzl and M. Nissl, "SoK: Timestamps are not a time model: Rethinking temporal reasoning in host-based intrusion detection," arXiv preprint arXiv:2610.35151, 2026, preprint, submitted October 26, 2026.

[21] N. Garg, V. V. Vazirani, and M. Yannakakis, "Multiway cuts in directed and node weighted graphs," in *International Colloquium on Automata, Languages, and Programming (ICALP)*, ser. Lecture Notes in Computer Science, vol. 820. Springer, 1994, pp. 487–498.

[22] M. Guo, M. Ward, A. Neumann, F. Neumann, and H. Nguyen, "Scalable edge blocking algorithms for defending active directory style attack graphs," in *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 37, no. 5, 2023, pp. 5649–5656.

[23] SigmaHQ, "Sigma rule repository: Windows certificate template and certificate authentication rules," 2026, executed with pySigma 2.1.0 and SQLite backend 2.1.1; upstream commit d7c9da10c170a6988d68ebdf2c9f7bd8782b7c55, accessed November 10, 2026. [Online]. Available: https://github.com/SigmaHQ/sigma

[24] Microsoft, "October 13, 2026—KB5126651 (OS build 17763.9376)," Microsoft Support, 2026, october 2026 security build 17763.9376; applicable Server 2019 update verified in the laboratory. [Online]. Available: https://support.microsoft.com/en-us/servicing/os/windows-10/2026/10/kb5126651-windows-10-1809-security-update

[25] ——, "MS-PKCA, section 3.1.5.2.1.6: SID," Microsoft Open Specifications, 2025, updated June 3, 2025; accessed November 10, 2026. [Online]. Available: https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-pkca/e8fd2c1d-50d3-493a-9b58-5e453850c567

[26] Microsoft Security Research, S. Patil, J. Birch, and T. Tzhori, "From help desk impersonation to AD CS abuse: Investigating ESC1 and ESC8 intrusion paths," Microsoft Security Blog, October 30, 2026, accessed 2026-11-10; vendor investigation, not a peer-reviewed comparative benchmark. [Online]. Available: https://www.microsoft.com/en-us/security/blog/2026/10/30/help-desk-impersonation-ad-cs-abuse-investigating-esc1-esc8-intrusion-paths/

[27] Unit 42, "Inside AD CS escalation: Unpacking advanced misuse techniques and tools," Palo Alto Networks Unit 42, 2026, accessed 2026-11-10; vendor technical research. [Online]. Available: https://unit42.paloaltonetworks.com/active-directory-certificate-services-exploitation/

[28] T. N. Kipf and M. Welling, "Semi-supervised classification with graph convolutional networks," in *International Conference on Learning Representations (ICLR)*, 2017.

[29] P. Veličković, G. Cucurull, A. Casanova, A. Romero, P. Liò, and Y. Bengio, "Graph attention networks," in *International Conference on Learning Representations (ICLR)*, 2018.

[30] T. Pasquier, X. Han, T. Moyer, M. Bates, O. Hermant, D. Eyers, J. Bacon, and M. Seltzer, "Practical whole-system provenance capture," in *Proceedings of the ACM Symposium on Cloud Computing (SoCC)*, 2017, pp. 405–418.

[31] X. Han, T. Pasquier, A. Bates, J. Mickens, and M. Seltzer, "Unicorn: Runtime provenance-based detector for advanced persistent threats," in *Network and Distributed System Security Symposium (NDSS)*, 2020.

[32] W. U. Hassan, S. Guo, D. Li, M. Chen, K. Jee, Z. Li, and A. Bates, "Tactical provenance analysis for endpoint detection and response systems," in *IEEE Symposium on Security and Privacy (S&P)*, 2020, pp. 1172–1189.

[33] M. Tambe, *Security and Game Theory: Algorithms, Deployed Systems, Lessons Learned*. Cambridge University Press, 2011.

[34] E. Dahlhaus, D. S. Johnson, C. H. Papadimitriou, P. D. Seymour, and M. Yannakakis, "The complexity of multiterminal cuts," *SIAM Journal on Computing*, vol. 23, no. 4, pp. 864–894, 1994.

[35] H. Q. Ngo, M. Guo, and H. X. Nguyen, "Optimizing cyber response time on temporal active directory networks using decoys," in *Proceedings of the Genetic and Evolutionary Computation Conference*, ser. GECCO '24. New York, NY, USA: Association for Computing Machinery, 2024, pp. 1309–1317.